RAPPORT DE PROJET

Projet MediConnect

Sécurisation de l'interconnexion d'une plateforme de santé à Internet

Mise en œuvre et tests selon le guide ANSSI PA-066

Module : **Sécurité des réseaux**

Enseignant : **Salim Benayoune**

Réalisé par

DOSSOU Sam

Cycle ingénieur ING2, EFREI Paris

Année universitaire 2026-2027 | Remise : octobre 2026

Sommaire

Cliquer sur un titre pour accéder directement à la partie correspondante.

1. Introduction et contexte....3
1.1 Démarche suivie....3
1.2 Besoins d'interconnexion (R1)....3

2. Architecture retenue....4
2.1 Principes structurants....4
2.2 Chemin des flux principaux....5

3. Plan d'adressage, zones et niveaux de confiance....6
3.1 Mise en œuvre de l'adressage et du routage....6

4. Protection de la DMZ et séparation production / démonstration....8
4.1 Publication des services....8
4.2 Relais applicatifs (reverse proxies)....8
4.3 Cloisonnement entre la DMZ et le SI interne....9
4.4 Zone de démonstration....9

5. VPN utilisés....10
5.1 VPN IPsec site à site....10
5.2 VPN SSL d'accès distant....11

6. Authentification et règles basées sur l'identité....13
6.1 Annuaire dédié aux accès distants....13
6.2 Droits par groupe....13
6.3 Authentification à deux facteurs des médecins....15

7. Politique de filtrage....18
7.1 Principes....18
7.2 Pare-feu externe....18
7.3 Pare-feu interne....19
7.4 Une politique corrigée grâce aux journaux....20

8. Contrôle applicatif....22
8.1 Inspection par l'IPS....22
8.2 Relais sortant....23

9. Sécurisation de l'administration....25

10. Stratégie de journalisation....29

11. Tests réalisés....31
11.1 Tests fonctionnels....31
11.2 Tests depuis un poste attaquant....31
11.3 Traces côté défense....33

12. Limites de la solution....35

13. Conclusion....36

Annexe A. Correspondance avec les recommandations ANSSI....37

Annexe B. Inventaire de la maquette....38

1. Introduction et contexte

MediConnect est une plateforme de prise de rendez-vous médicaux. Elle expose deux services sur Internet : un **portail destiné aux patients** et un **espace professionnel réservé aux médecins**. Le siège héberge également des applications internes (CRM, comptabilité, support), un **site secondaire** (site B) lui est relié, et des collaborateurs travaillent en mobilité : commerciaux, comptables, équipe support et administrateurs d'astreinte.

L'objectif du projet est de concevoir, déployer et tester une interconnexion sécurisée de ce système d'information à Internet. La démarche suit le guide de l'ANSSI **« Recommandations relatives à l'interconnexion d'un système d'information à Internet » (PA-066, version 3)**. Les références R1, R2, etc. citées dans ce rapport renvoient aux recommandations de ce guide ; l'annexe A en donne la correspondance complète.

Le travail a été réalisé en monôme, sur une maquette complète sous VirtualBox : trois pare-feux, sept serveurs Debian et trois postes clients. Les configurations (sans aucun secret) et les 130 captures d'écran sont versionnées dans un dépôt Git ; une sélection de ces captures illustre ce rapport.

1.1 Démarche suivie

- **Cadrage** : expression des besoins d'interconnexion (R1), découpage en zones, plan d'adressage, matrice des flux.
- **Mise en œuvre progressive** : chaque brique (adressage, publication, VPN, identité, administration, journalisation) est testée avant de passer à la suivante.
- **Journal de bord** tenu tout au long du projet : choix, difficultés, corrections et preuves.
- **Campagne de tests finale** depuis un poste attaquant placé sur Internet, avec vérification des traces côté défense.

1.2 Besoins d'interconnexion (R1)

Seuls les besoins suivants justifient une ouverture vers ou depuis Internet. Tout autre flux est refusé.

Service	Sens	Population concernée
Portail patients en HTTPS	Entrant	Internet (public)
Espace médecins en HTTPS avec MFA	Entrant	Médecins
VPN SSL d'accès distant	Entrant	Commerciaux, comptables, support, administrateurs
Tunnel IPsec site à site	Entrant et sortant	Pare-feu du site B uniquement
Environnement de démonstration	Entrant, par le VPN	Commerciaux
Navigation et mises à jour	Sortant, par un relais	Postes du LAN du siège

2. Architecture retenue

L'architecture repose sur une passerelle à **deux niveaux de filtrage** : un pare-feu externe face à Internet et un pare-feu interne qui protège le système d'information. Conformément aux recommandations R2, R3 et R13, ces deux pare-feux sont des équipements distincts et de **technologies différentes** : une vulnérabilité affectant un éditeur ne suffit pas à traverser toute la passerelle.

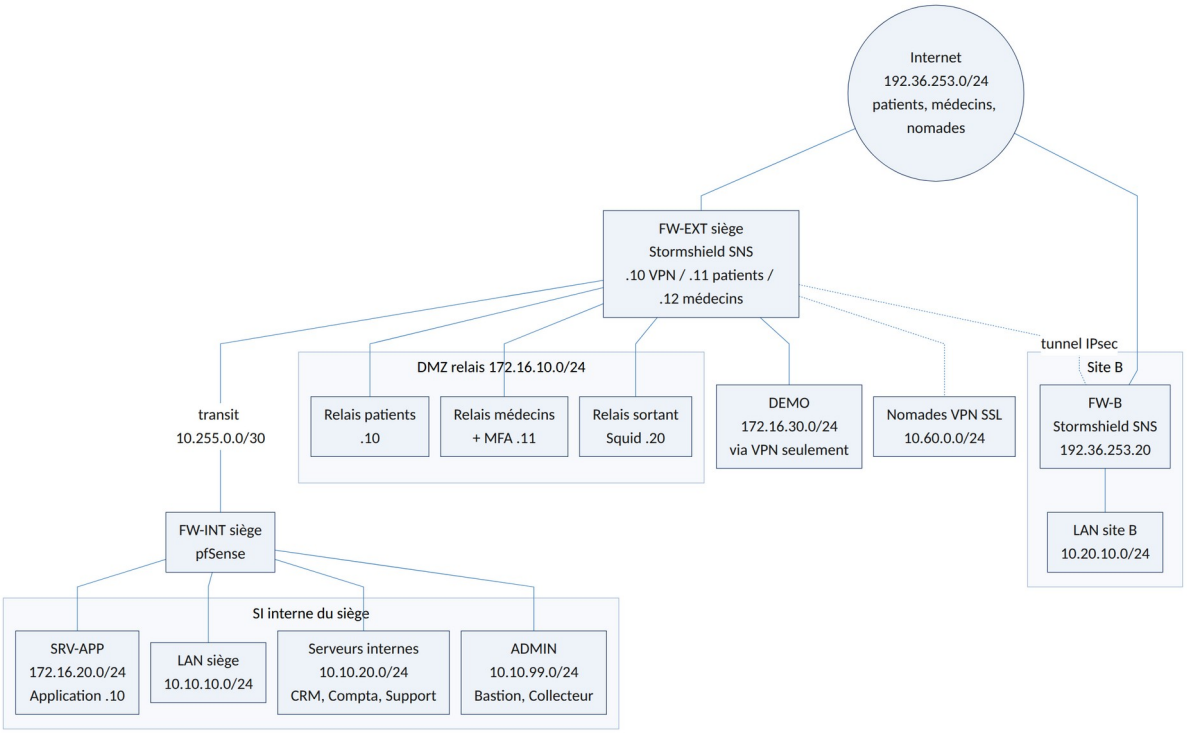


Figure 1 : *Architecture retenue. Le pare-feu externe (Stormshield) fait face à Internet et porte la DMZ des relais (relais patients, relais médecins avec MFA, relais sortant), la zone de démonstration réservée au VPN et le VPN SSL des nomades. Il est relié par le réseau de transit au pare-feu interne (pfSense), qui protège l'application, le LAN, les serveurs internes et la zone d'administration. Le site B rejoint le siège par un tunnel IPsec.*

Équipement	Rôle	Technologie
MC-FW-EXT	Pare-feu externe du siège : publication des services, DMZ, zone de démonstration, VPN IPsec et SSL, inspection (IPS), annuaire des nomades	Stormshield SNS EVA 4.8
MC-FW-INT	Pare-feu interne : protège le LAN, les serveurs internes, l'application et la zone d'administration	pfSense 2.8.1
MC-FW-B	Pare-feu du site B, extrémité du tunnel IPsec	Stormshield SNS EVA
Serveurs	Relais entrants et portail MFA, application, démonstration, applications internes, bastion et collecteur, relais sortant	Debian 13 minimal, sans interface graphique

Les serveurs sont des clones liés d'un **modèle unique** installé au minimum (aucun environnement graphique, uniquement les paquets nécessaires), ce qui réduit la surface d'attaque et garantit une base homogène. Un script de rôle configure ensuite chaque clone (adresse, nom, services).

2.1 Principes structurants

- **Défense en profondeur** : un flux venant d'Internet traverse le pare-feu externe, un relais de la DMZ, puis le pare-feu interne avant d'atteindre l'application.

- **Rupture protocolaire (R8)** : les relais terminent la session TLS du client et en ouvrent une nouvelle vers l'application.
- **Aucun flux initié depuis la DMZ vers le SI interne (R7)**, à l'exception du relais vers l'application, sur un port unique.
- **Routage statique** partout et **aucune route par défaut** sur le pare-feu interne (R19).
- **Tout est interdit sauf ce qui est explicitement autorisé**, avec rejet silencieux côté Internet (R20).
- **Administration** uniquement depuis une zone dédiée, à travers un bastion (R16).
- **Journalisation centralisée** dans la zone la mieux protégée (R26).

2.2 Chemin des flux principaux

Flux	Chemin suivi
Patient	Internet, adresse publique .11 du pare-feu externe, relais patients (DMZ), pare-feu interne, application
Médecin	Internet, adresse publique .12, relais médecins et portail MFA (DMZ), pare-feu interne, application
Nomade	Internet, VPN SSL sur l'adresse .10, filtrage selon le groupe de l'utilisateur, pare-feu interne, application interne autorisée
Site B	LAN du site B, pare-feu du site B, tunnel IPsec, pare-feu externe, pare-feu interne, zone SERVEURS
Navigation du LAN	Poste du LAN, pare-feu interne, relais sortant (DMZ), pare-feu externe avec masquage d'adresse, Internet
Administration	Poste d'administration, bastion (zone ADMIN), interfaces d'administration des pare-feux

3. Plan d'adressage, zones et niveaux de confiance

Chaque zone regroupe des machines de **même niveau de confiance**, et toute communication entre deux zones passe par un pare-feu. Le niveau de confiance détermine ce qu'une zone a le droit d'initier : une zone de confiance faible ne peut jamais ouvrir de connexion vers une zone de confiance plus élevée.

Zone	Réseau	Passerelle	Confiance	Contenu
INTERNET	192.36.253.0/24	NAT VirtualBox	Nulle	Clients, attaquant de test
DMZ-RELAIS	172.16.10.0/24	FW-EXT .254	Faible, jugée compromissible	Relais patients .10, relais médecins et MFA .11, relais sortant .20
DEMO	172.16.30.0/24	FW-EXT .254	Faible, isolée	Plateforme de démonstration .10, données fictives
VPN-NOMADES	10.60.0.0/24	FW-EXT	Moyenne, utilisateurs authentifiés	Adresses attribuées aux nomades
TRANSIT	10.255.0.0/30	FW-EXT .1, FW-INT .2	Lien entre pare-feux	Aucun hôte
SRV-APP	172.16.20.0/24	FW-INT .254	Moyenne	Application MediConnect .10 (port 8443)
LAN-SIEGE	10.10.10.0/24	FW-INT .254	Élevée	Postes du siège, poste d'administration .2
SERVEURS	10.10.20.0/24	FW-INT .254	Élevée	CRM .20, comptabilité .30, support .40
ADMIN	10.10.99.0/24	FW-INT .254	Maximale	Bastion .10, collecteur de journaux .20
LAN-SITE-B	10.20.10.0/24	FW-B .254	Élevée	Postes du site B

Les plages sont distinctes par usage (10.10.x pour le siège, 10.20.x pour le site B, 10.60.x pour les nomades, 172.16.x pour les zones exposées), ce qui rend règles et journaux lisibles sans ambiguïté. Sur Internet, le pare-feu externe porte trois adresses : **.10** (VPN SSL et IPsec), **.11** (publication patients) et **.12** (publication médecins). Le site B utilise l'adresse .20.

L'application est isolée dans sa propre zone (SRV-APP), derrière le pare-feu interne : un relais compromis ne peut l'atteindre que sur un seul port, et n'a aucun accès au reste du SI.

3.1 Mise en œuvre de l'adressage et du routage

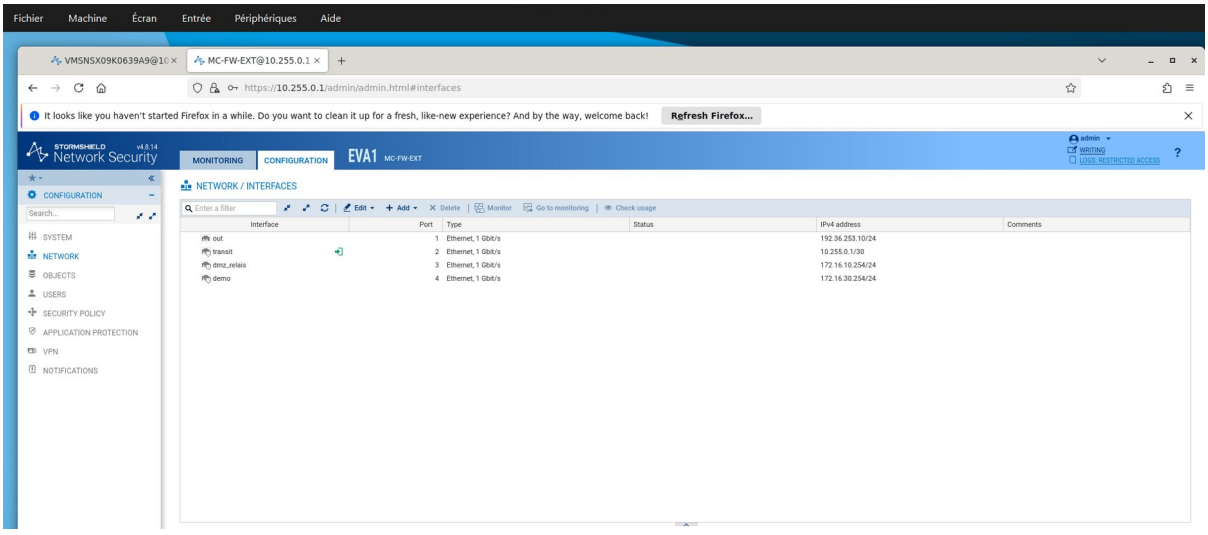


Figure 2 : *Interfaces du pare-feu externe en mode routé : out (192.36.253.10, côté Internet), dmz_relais, demo et transit. Le pont d'usine a été supprimé pour que chaque zone ait son propre réseau et que tout passage d'une zone à l'autre soit filtré.*

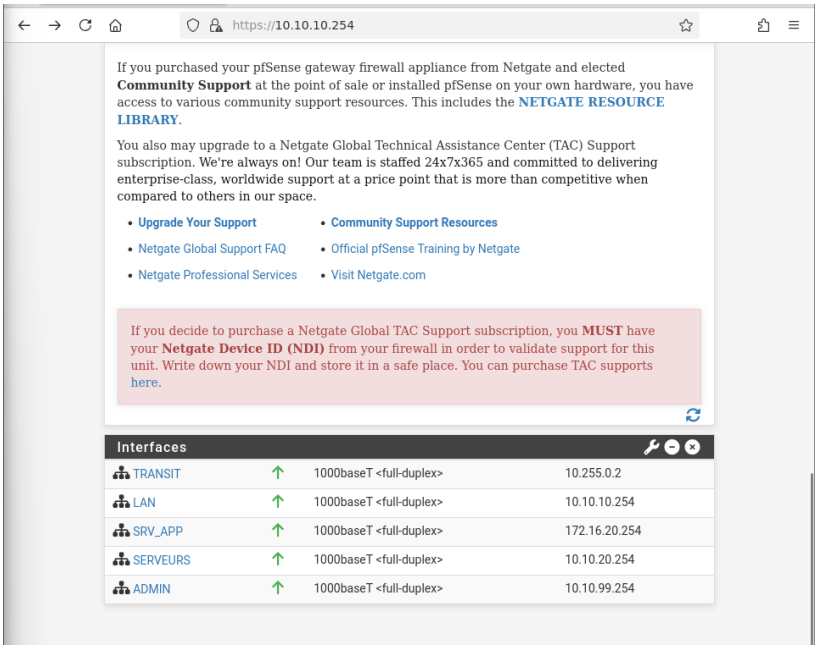


Figure 3 : *Les cinq interfaces du pare-feu interne (pfSense), une par zone : TRANSIT, LAN, SRV_APP, SERVEURS et ADMIN. Chaque zone interne est ainsi séparée des autres par une règle de filtrage.*

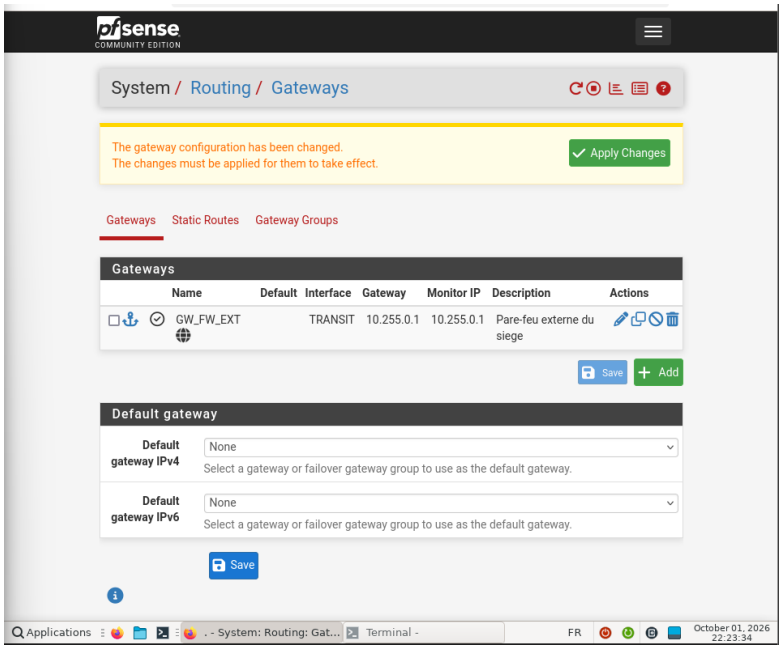


Figure 4 : *Pare-feu interne : la passerelle vers le pare-feu externe est déclarée, mais les passerelles par défaut IPv4 et IPv6 restent sur « None » (R19). Seules des routes statiques explicites mènent vers les zones situées derrière le pare-feu externe.*

Difficulté rencontrée. Lors du premier test de bout en bout, le pare-feu externe bloquait le retour vers le LAN avec des alarmes « IP address spoofing ». Les réseaux internes avaient été déclarés comme des hôtes au lieu de réseaux, si bien que le pare-feu jugeait illégitimes les adresses du LAN derrière l'interface transit. Une fois les objets recréés en type réseau avec leur masque, le trafic est passé. Leçon retenue : sur Stormshield, une route statique sert aussi à déclarer quels réseaux sont légitimes derrière une interface (protection anti-usurpation).

4. Protection de la DMZ et séparation production / démonstration

4.1 Publication des services

Les deux services sont publiés par **NAT de destination**, uniquement en HTTPS, sur deux adresses publiques distinctes. Chaque population dispose de sa propre chaîne complète (adresse publique, relais, règles) : c'est l'application de la recommandation **R6** sur la séparation des chaînes de traitement.

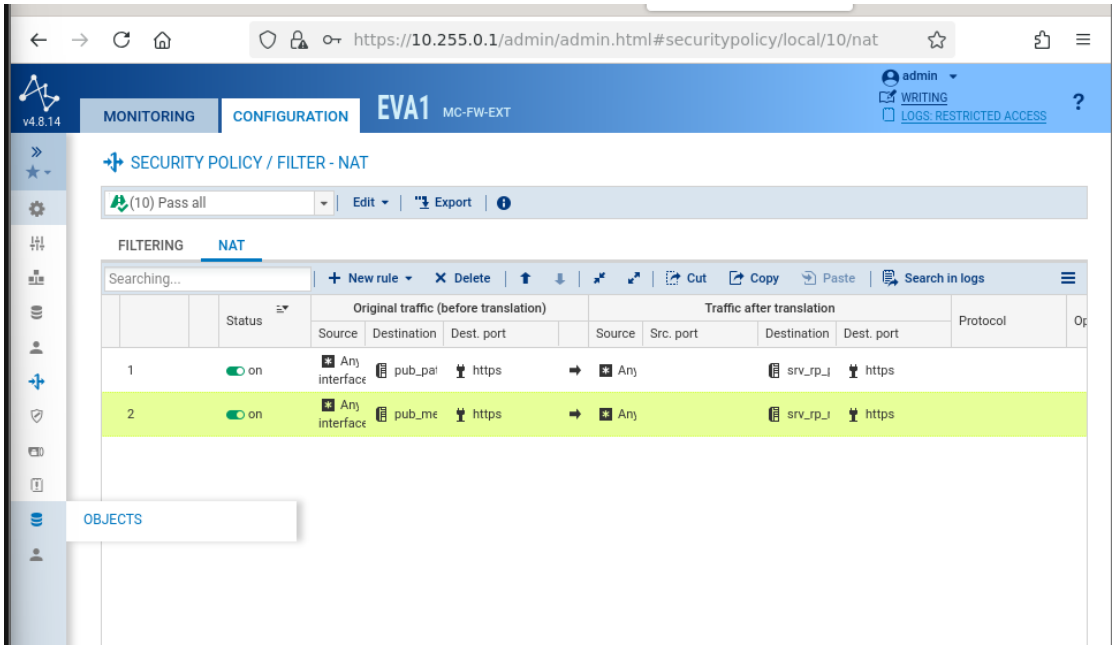


Figure 5 : *Les deux règles de publication du pare-feu externe : l'adresse publique patients est traduite vers le relais patients, l'adresse publique médecins vers le relais médecins, et seulement pour le service HTTPS.*

4.2 Relais applicatifs (reverse proxies)

Les relais nginx de la DMZ terminent la session TLS du client et ouvrent une nouvelle session vers l'application sur le port 8443 (**rupture protocolaire, R8**). Le serveur d'application n'accepte que ces deux relais. La chaîne patients refuse explicitement l'espace professionnel, et nginx ne divulgue pas son numéro de version.

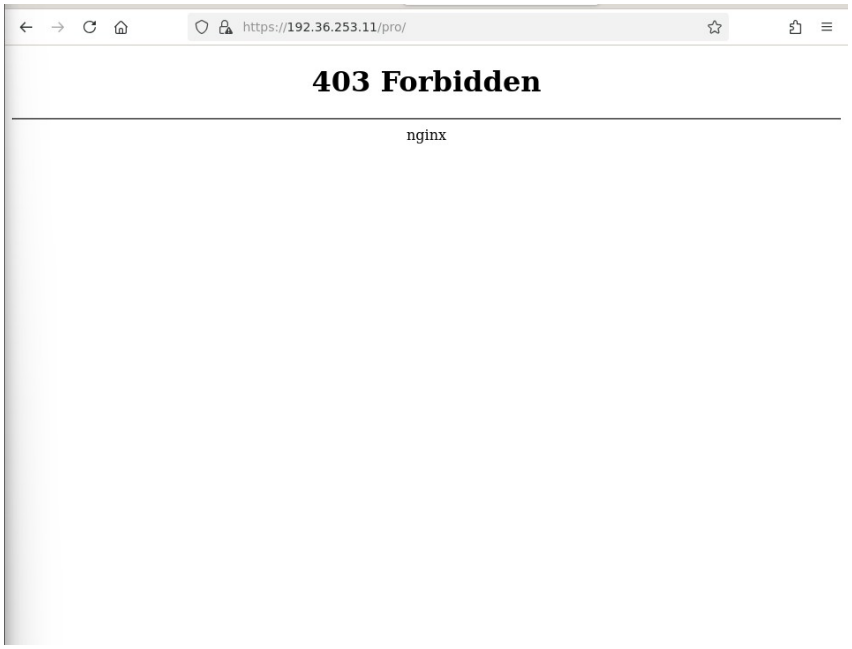


Figure 6 : *Depuis Internet, une requête vers l'espace professionnel par l'adresse des patients est refusée (403). Un patient, ou un attaquant passant par la chaîne publique, ne peut pas atteindre les pages réservées aux médecins.*

4.3 Cloisonnement entre la DMZ et le SI interne

Sur le pare-feu interne, **une seule règle** laisse entrer un flux venant de la DMZ : les relais vers l'application, en TCP 8443. Aucun autre flux initié depuis la DMZ n'est autorisé vers l'intérieur (**R7**). Une compromission d'un relais reste donc confinée.

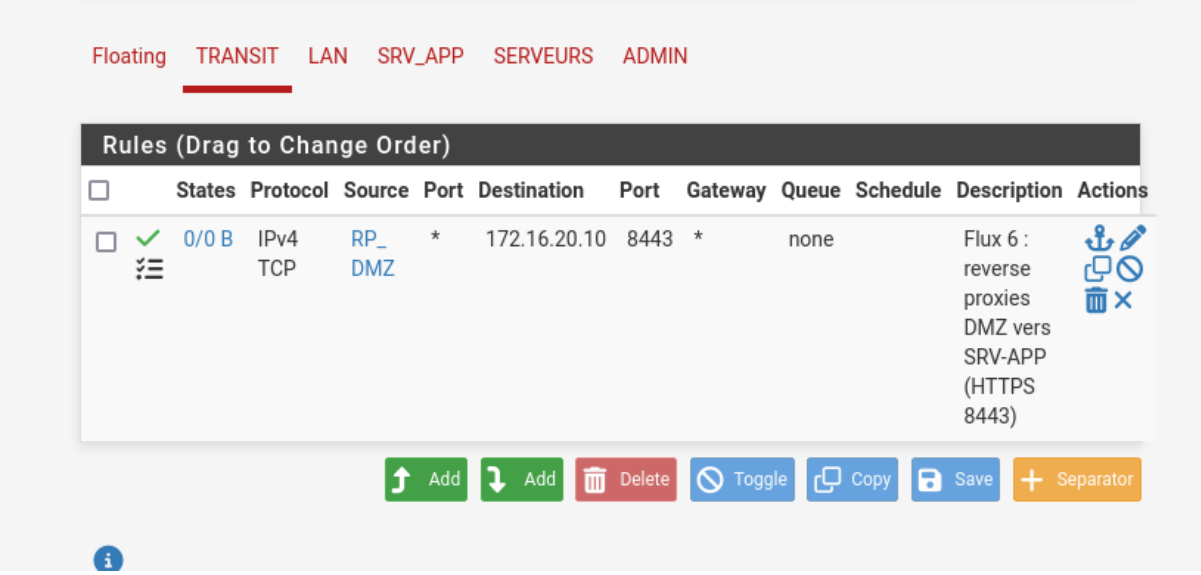


Figure 7 : *Interface TRANSIT du pare-feu interne au moment de la publication : la seule autorisation venant de la DMZ concerne les relais (alias RP_DMZ) vers l'application 172.16.20.10 en TCP 8443, avec journalisation.*

4.4 Zone de démonstration

L'environnement de démonstration est séparé de la production : réseau propre, données fictives, et aucun droit d'initier une connexion vers la DMZ, l'application ou le SI interne. Conformément au cadrage, il n'est **pas publié sur Internet** : seuls les commerciaux y accèdent, à travers le VPN SSL. Une publication temporaire réalisée en cours de projet a été identifiée comme un écart au cadrage et supprimée.

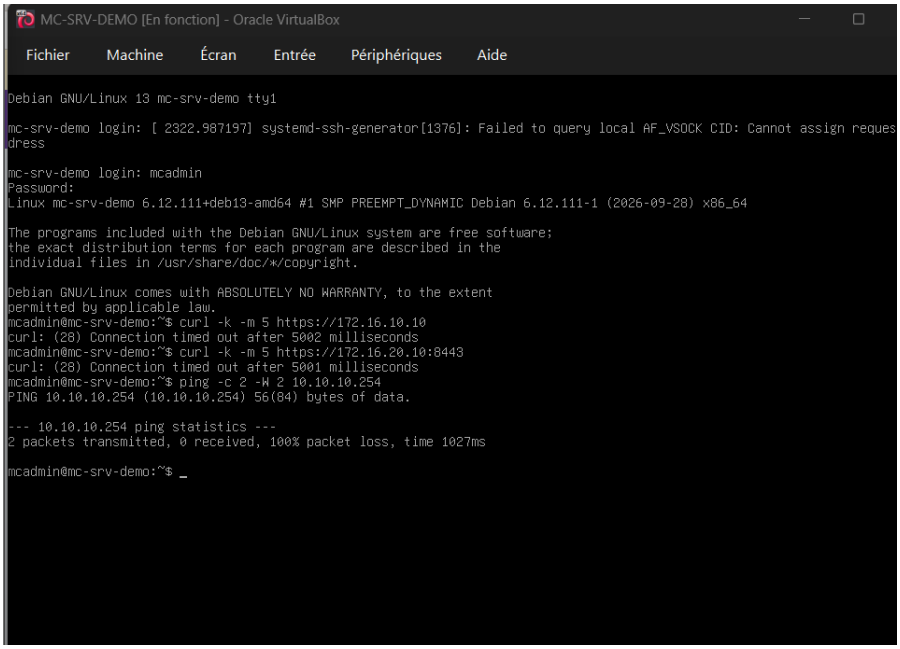


Figure 8 : *Depuis le serveur de démonstration, toutes les tentatives vers la DMZ, l'application et le réseau interne échouent : la zone DEMO est isolée et ne peut servir de point de rebond.*

5. VPN utilisés

5.1 VPN IPsec site à site

Le site B est relié au siège par un tunnel IPsec entre son pare-feu (192.36.253.20) et le pare-feu externe du siège (192.36.253.10). Paramètres : **IKEv2**, profil StrongEncryption (**AES-256, SHA-256, groupe Diffie-Hellman 28 pour la confidentialité persistante**). Le périmètre du tunnel est volontairement réduit au LAN du site B vers la seule zone SERVEURS du siège.

Le tunnel transporte, mais n'autorise rien à lui seul : le flux doit être permis sur trois équipements (pare-feu du site B, pare-feu externe, pare-feu interne). Sur le pare-feu externe, la source « LAN du site B » n'est acceptée que si elle arrive **par le tunnel IPsec**, ce qui empêche une usurpation de ces adresses depuis Internet.

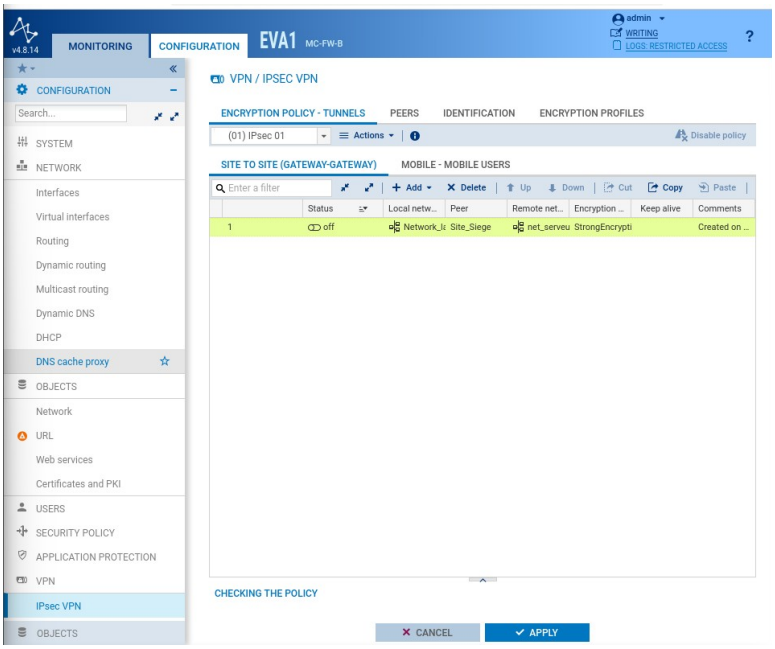


Figure 9 : *Configuration du tunnel sur le pare-feu du site B : réseau local du site B vers la zone SERVEURS du siège, correspondant « Site_Siege », profil de chiffrement StrongEncryption.*

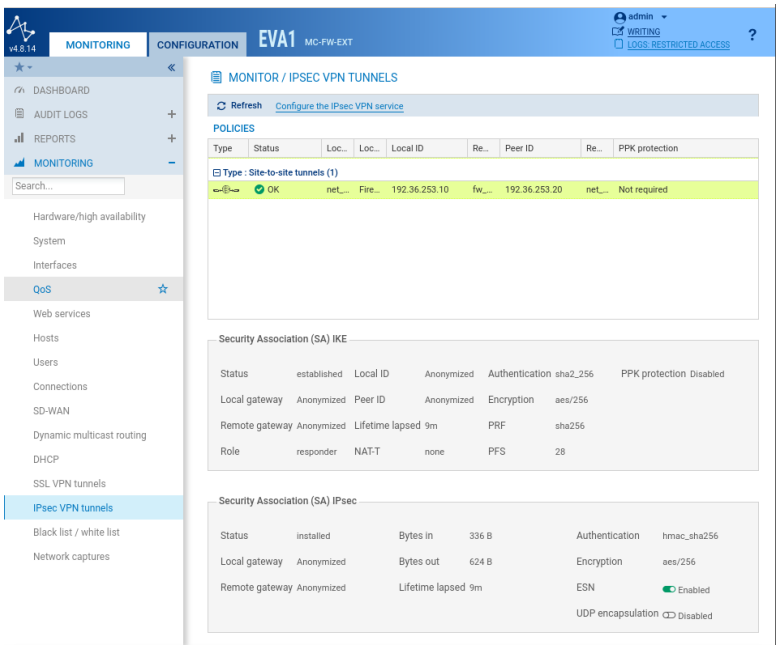


Figure 10 : *Supervision du tunnel sur le pare-feu externe : négociation IKE établie (AES-256, SHA-256, groupe 28) et association de sécurité IPsec installée, avec des octets échangés dans les deux sens.*

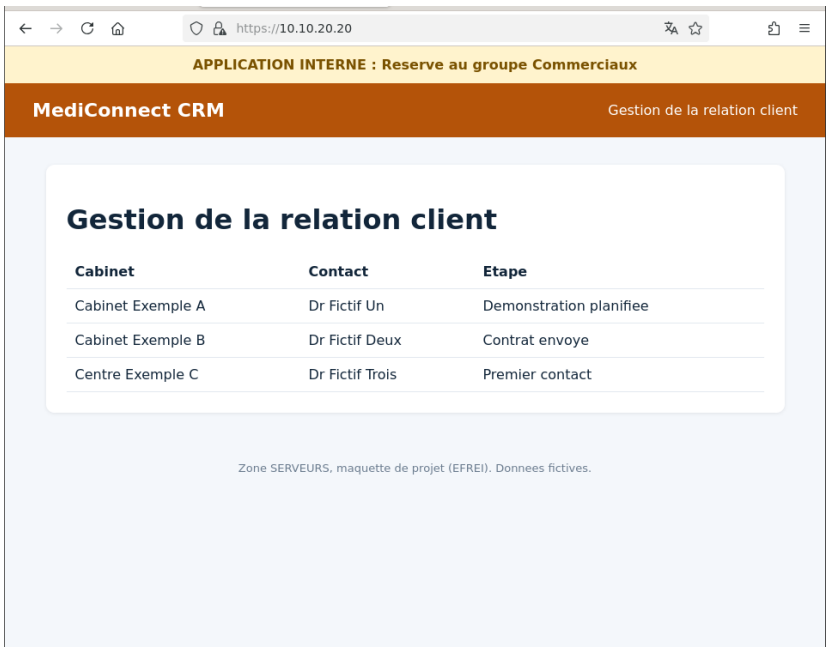


Figure 11 : *Depuis un poste du site B, l'application CRM de la zone SERVEURS s'affiche en HTTPS à travers le tunnel.*

```
~ $ ping -c 2 -W 2 10.10.10.254
PING 10.10.10.254 (10.10.10.254) 56(84) bytes of data.

--- 10.10.10.254 ping statistics ---
2 packets transmitted, 0 received, 100% packet loss, time 1010ms

~ $ ping -c 2 -W 2 172.16.10.10
PING 172.16.10.10 (172.16.10.10) 56(84) bytes of data.

--- 172.16.10.10 ping statistics ---
2 packets transmitted, 0 received, 100% packet loss, time 1011ms

~ $
```

Figure 12 : *Depuis ce même poste, le LAN du siège et la DMZ restent injoignables : le tunnel ne donne accès qu'à la zone SERVEURS, rien de plus.*

5.2 VPN SSL d'accès distant

Les nomades se connectent au VPN SSL du pare-feu externe (OpenVPN, TCP 443 et UDP 1194, adresse publique .10). Ils reçoivent une adresse dans 10.60.0.0/24 et n'ont accès qu'à une liste restreinte de ressources (zone SERVEURS, serveur de démonstration, bastion). L'authentification s'appuie sur l'annuaire dédié décrit en section 6. Le profil de connexion des clients n'est pas versionné dans le dépôt.

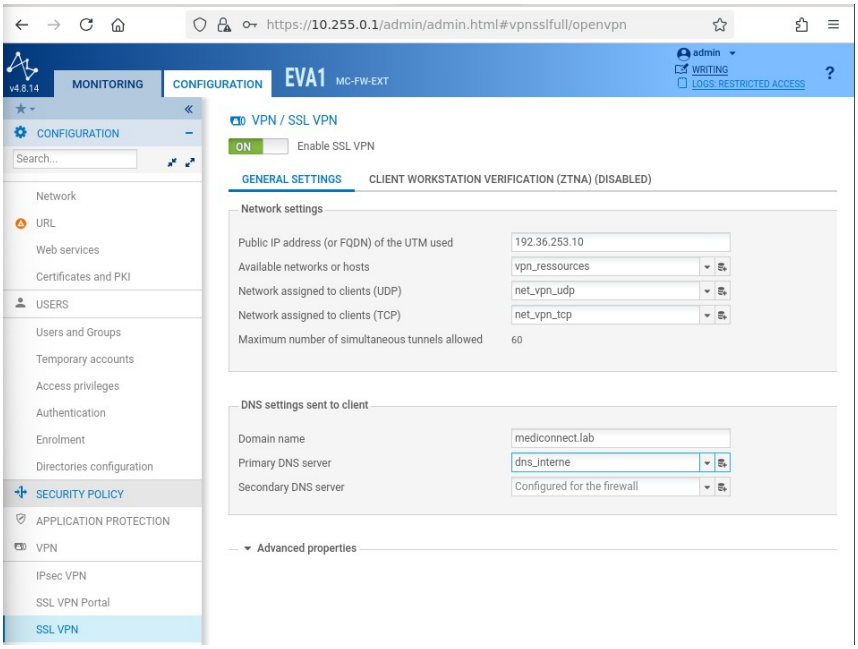


Figure 13 : *Service VPN SSL du pare-feu externe : adresse publique d'écoute, ressources accessibles limitées au groupe d'objets vpn_ressources, plages d'adresses distinctes pour les tunnels UDP et TCP.*

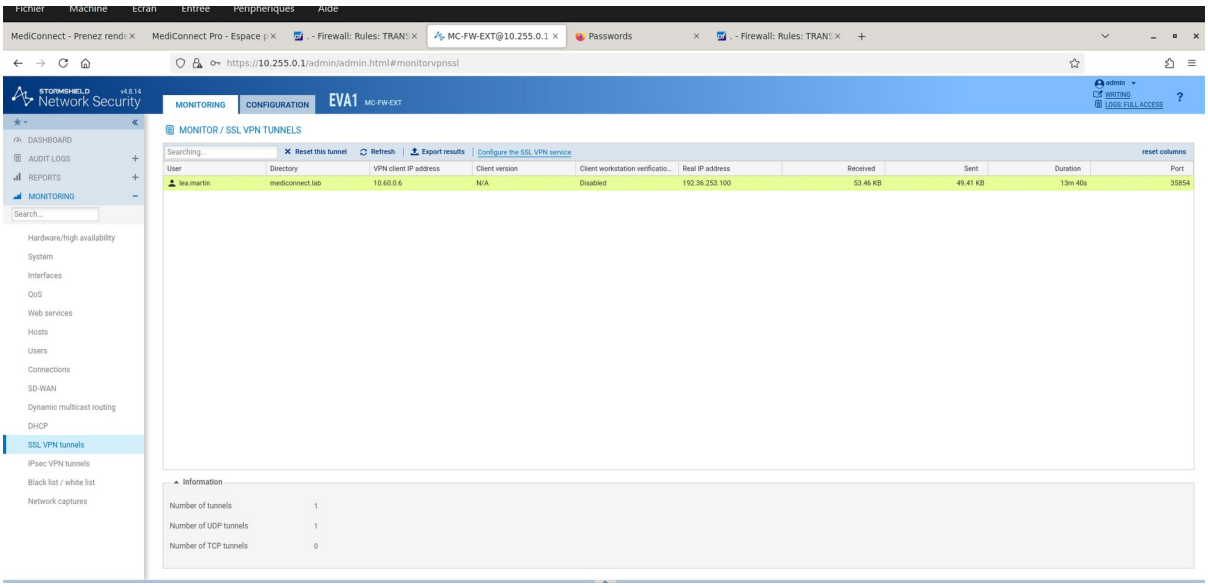


Figure 14 : *Supervision des tunnels VPN SSL : l'utilisatrice lea.martin, authentifiée par l'annuaire mediconnect.lab, reçoit l'adresse 10.60.0.6 ; son adresse réelle sur Internet est également tracée.*

6. Authentification et règles basées sur l'identité

6.1 Annuaire dédié aux accès distants

Les comptes des nomades sont stockés dans un **annuaire propre au pare-feu externe** (mediconnect.lab), distinct de tout annuaire interne : aucun annuaire du SI n'est interrogé depuis une zone exposée (**R10**). Quatre utilisateurs de test et quatre groupes ont été créés : commerciaux, comptabilite, support et administrateurs.

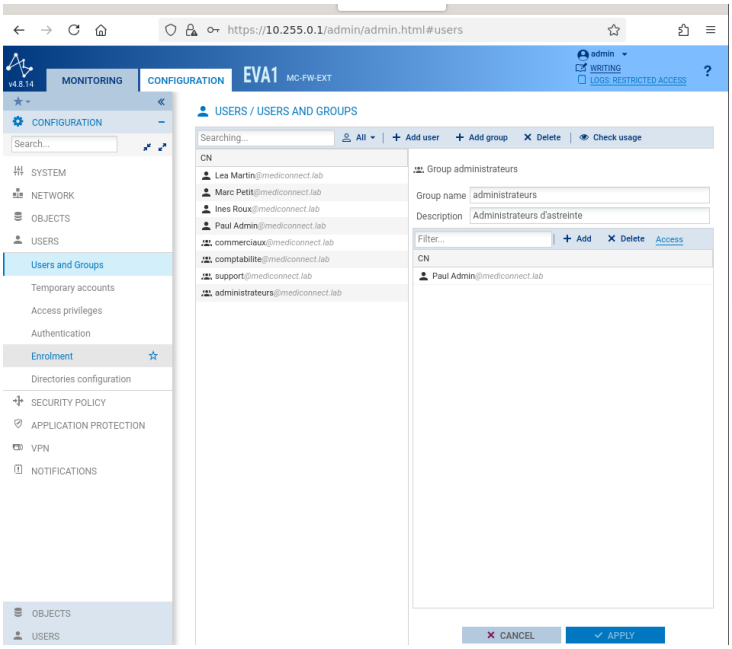


Figure 15 : *Annuaire mediconnect.lab du pare-feu externe : quatre utilisateurs de test répartis dans quatre groupes métier.*

6.2 Droits par groupe

Le contrôle d'accès est fait en deux temps. Le **droit de se connecter au VPN** est accordé utilisateur par utilisateur, et le refus est la règle par défaut. Le **droit d'atteindre une application** est donné par groupe, dans la politique de filtrage, avec une source restreinte aux flux arrivant par le tunnel VPN SSL :

Groupe	Applications autorisées	Exemple de compte
commerciaux	CRM et environnement de démonstration	lea.martin
comptabilite	Application de comptabilité	marc.petit
support	Application de support	ines.roux
administrateurs	Bastion en SSH uniquement	paul.admin

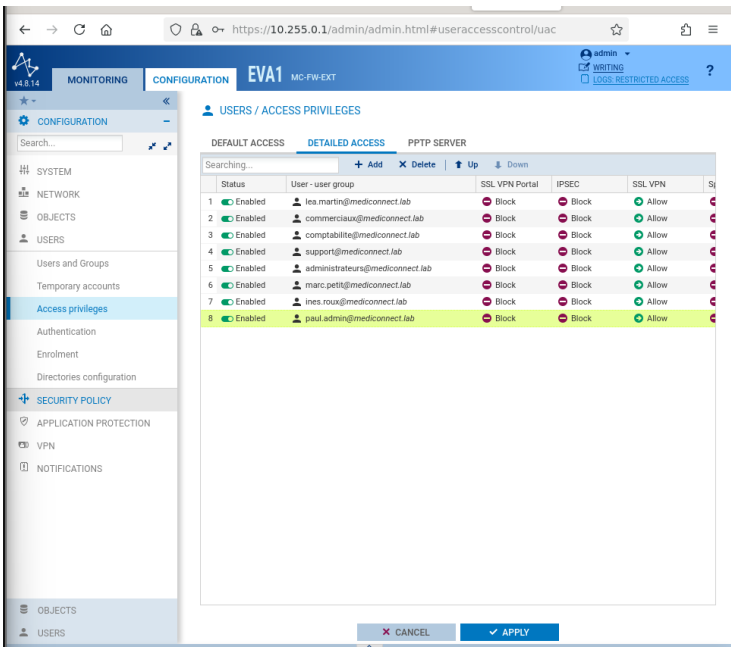


Figure 16 : *Droits d'accès détaillés : le VPN SSL est autorisé explicitement pour chaque utilisateur. Sur cette version, un droit accordé à un groupe n'était pas appliqué (refus « Access denied by UAC » relevé dans le journal VPN), d'où ce choix.*

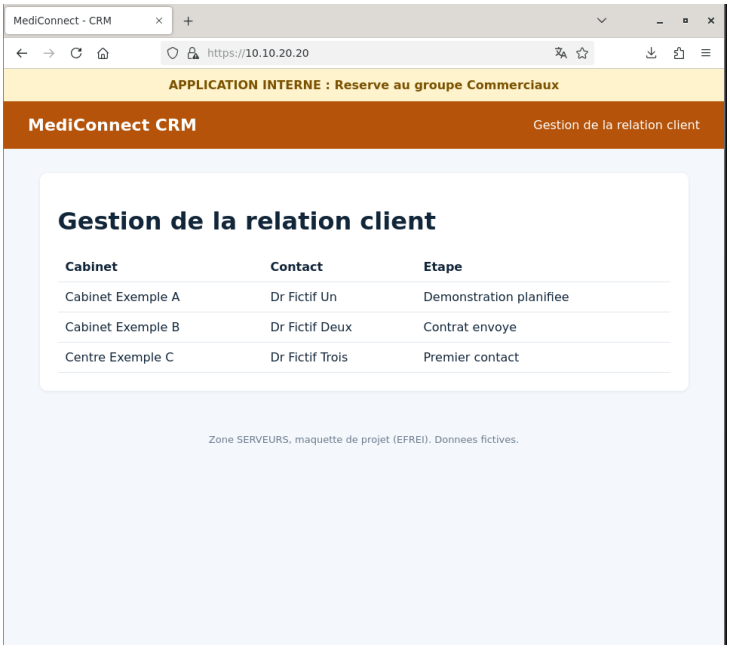


Figure 17 : *Test : la commerciale lea.martin, connectée en VPN SSL, accède au CRM, qui fait partie des ressources de son groupe.*

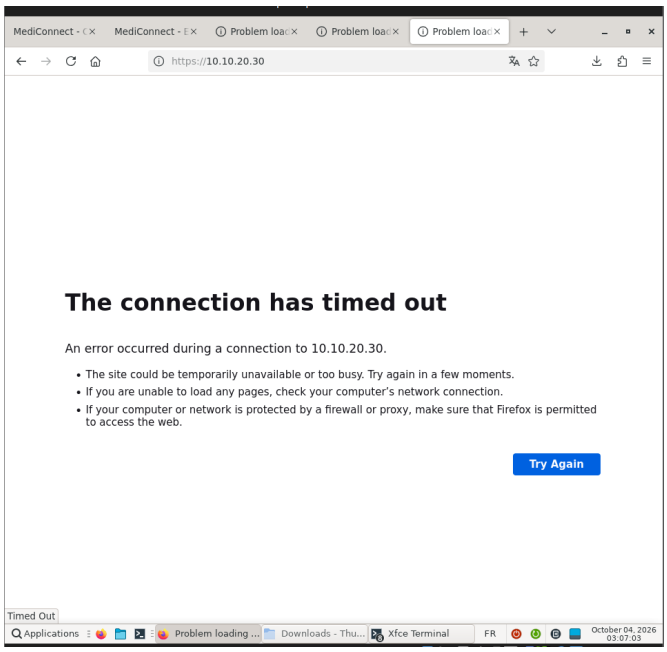


Figure 18 : *Même session : l'application de comptabilité reste inaccessible à la commerciale. Le filtrage par identité fonctionne.*

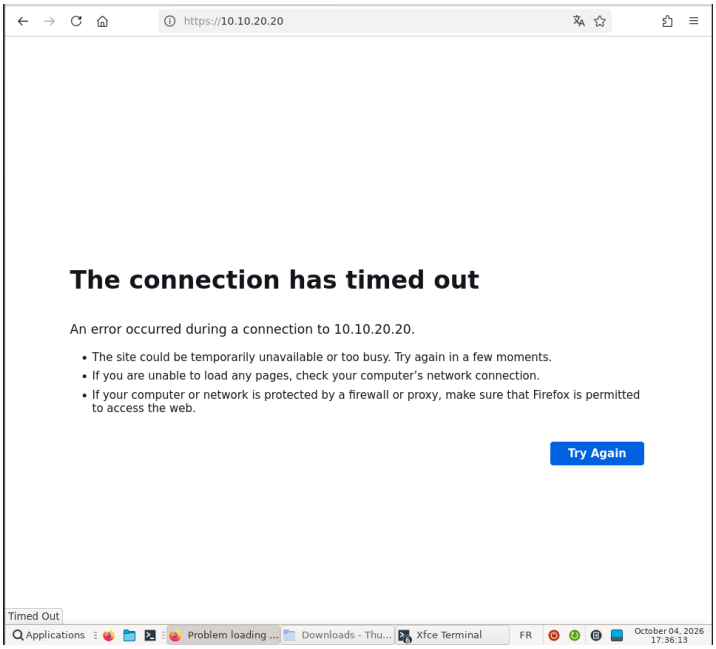


Figure 19 : *Test croisé avec le comptable marc.petit : le CRM lui est refusé alors qu'il accède à la comptabilité. Deux utilisateurs, depuis le même poste, obtiennent des droits différents selon leur groupe.*

6.3 Authentification à deux facteurs des médecins

Le sujet impose aux médecins un niveau de sécurité supérieur à celui des patients. L'espace professionnel est protégé par un **portail d'authentification à deux facteurs** placé sur le relais : mot de passe et code à usage unique TOTP (RFC 6238, six chiffres renouvelés toutes les 30 secondes), généré par une application d'authentification sur téléphone. nginx interroge ce portail avant chaque requête vers l'espace professionnel ; sans session valide, l'utilisateur est redirigé vers la page de connexion. La base des médecins est locale à la DMZ (**R10**).

- Mots de passe stockés sous forme d'empreinte PBKDF2-SHA256 salée.
- Cookie de session signé, marqué Secure, HttpOnly et SameSite=Strict, valable 15 minutes.
- Blocage de 5 minutes après 5 échecs pour un même identifiant et une même adresse.

- Refus du rejeu d'un code déjà utilisé ; même message et même temps de réponse, que l'identifiant existe ou non.
- Journal des tentatives avec l'adresse du client, sans jamais enregistrer ni mot de passe ni code.
- Service exécuté sous un compte dédié, avec un système de fichiers en lecture seule.

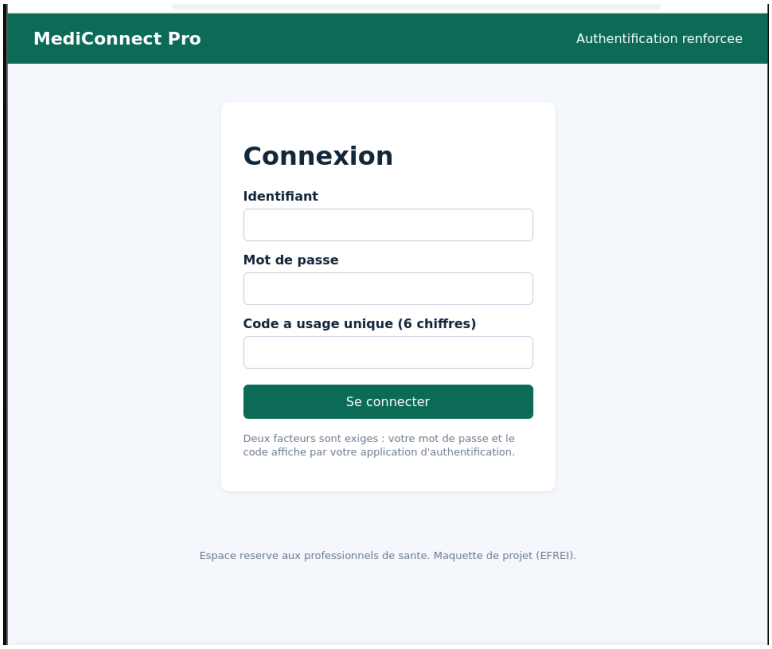


Figure 20 : *Depuis Internet, l'adresse des médecins mène d'abord au portail d'authentification renforcée : aucune page professionnelle n'est servie sans authentification.*

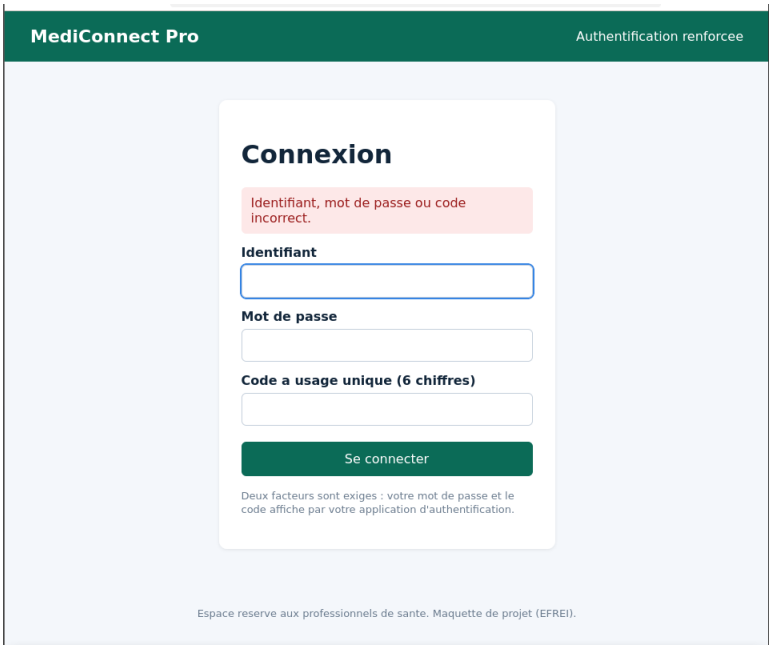


Figure 21 : *Identifiant et mot de passe corrects, mais code à usage unique faux : l'accès est refusé avec un message volontairement non précis, qui ne révèle pas quel facteur est erroné.*

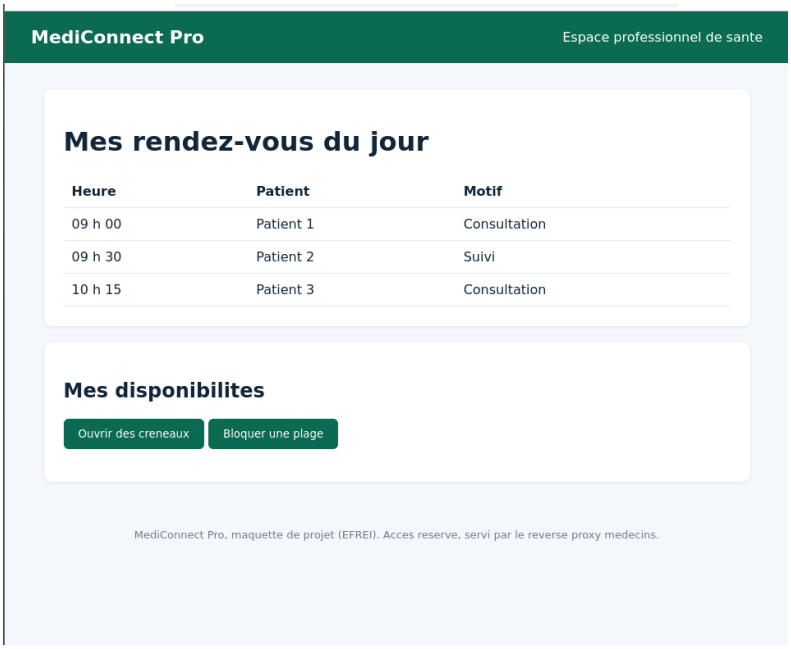


Figure 22 : *Après saisie du mot de passe et du code affiché par le téléphone, l'espace professionnel s'affiche.*

```
mcadmin@mc-srv-relais:~$ sudo tail -n 8 /var/log/mediconnect/mfa.log
2026-10-04 05:37:34 START user=- ip=- ecoute sur 127.0.0.1:9000
2026-10-05 15:37:10 LOGIN_OK user=dr.dupont ip=192.36.253.100 mot de passe et code TOTP valides
2026-10-05 15:38:09 LOGIN_OK user=dr.dupont ip=192.36.253.100 mot de passe et code TOTP valides
2026-10-05 15:40:40 LOGOUT user=dr.dupont ip=192.36.253.100
2026-10-05 15:41:41 LOGIN_OK user=dr.dupont ip=192.36.253.100 mot de passe et code TOTP valides
2026-10-05 15:42:07 LOGIN_FAIL user=dr.dupont ip=192.36.253.100 code TOTP invalide
mcadmin@mc-srv-relais:~$ _
```

Figure 23 : *Journal du portail MFA : connexions réussies, déconnexion et refus pour code invalide, avec l'adresse réelle du client. Ni mot de passe ni code n'y figurent.*

7. Politique de filtrage

7.1 Principes

- **Liste blanche** : chaque règle autorise un flux identifié dans la matrice des flux ; une règle finale bloque tout le reste et le journalise.
- Règles ordonnées de la plus précise à la plus générale, chacune commentée.
- **Rejet silencieux** côté Internet (R20) : un paquet refusé ne reçoit aucune réponse, ce qui ne donne aucune information à un attaquant.
- Sur Stormshield, le filtrage est évalué **avant** la traduction d'adresse : les règles visent donc les adresses publiques.
- Sources et services restreints au strict nécessaire, avec journalisation des flux sensibles.

7.2 Pare-feu externe

État final de la politique MediConnect du pare-feu externe (une politique « Pass all » est conservée à part comme secours, inactive) :

N°	Source	Destination	Service	Rôle
1	Bastion	Pare-feu (interface transit)	HTTPS	Administration depuis le bastion seul
2	Internet, interface out	Adresse publique patients	HTTPS	Portail patients
3	Internet, interface out	Adresse publique médecins	HTTPS	Espace médecins
4	Relais patients et médecins	Application	TCP 8443	Relais vers application (R7)
5	LAN du siège	Relais sortant	TCP 3128	Navigation, profil IPS dédié
6	Relais sortant	Internet	HTTP, HTTPS	Sortie du relais
7	Relais sortant	Deux résolveurs DNS nommés	DNS	Résolution des noms
8	LAN, zone ADMIN	Tout	ICMP echo	Diagnostic
9	Pare-feu interne	Interface transit	ICMP echo	Supervision de passerelle
10, 11	LAN du site B, via IPsec	Zone SERVEURS	HTTPS, ICMP	Site B
12	commerciaux, via VPN SSL	CRM, démonstration	HTTPS	Identité
13	comptabilite, via VPN SSL	Comptabilité	HTTPS	Identité
14	support, via VPN SSL	Support	HTTPS	Identité
15	administrateurs, via VPN SSL	Bastion	SSH	Identité, administration
16	Tout	Tout	Tout	Blocage journalisé (R20)

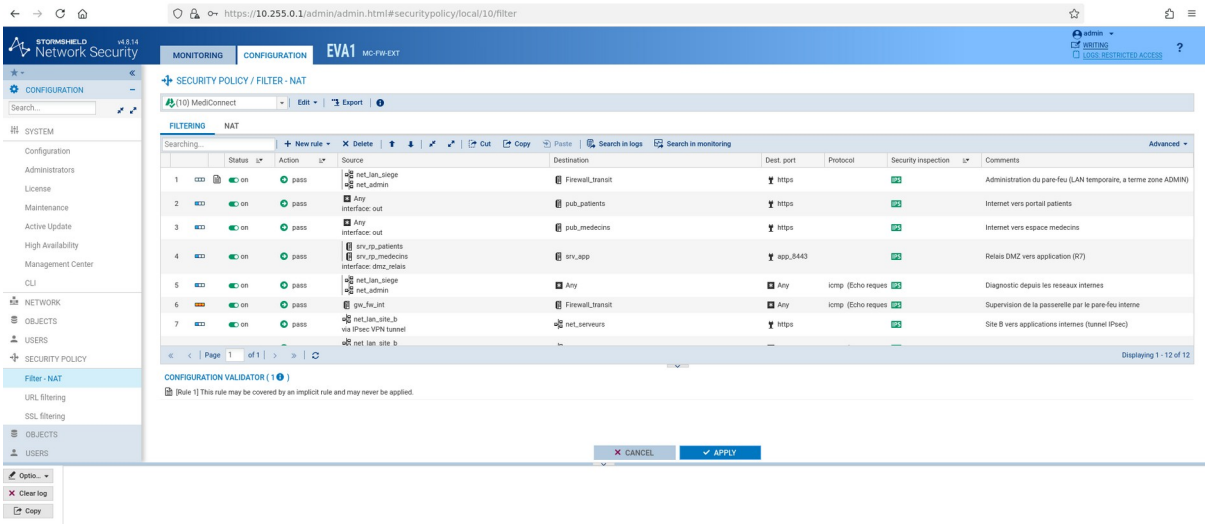


Figure 24 : *Politique du pare-feu externe telle qu'affichée dans l'interface (état du 4 octobre, avant l'ajout des règles du relais sortant) : autorisations précises, commentées, puis blocage final.*

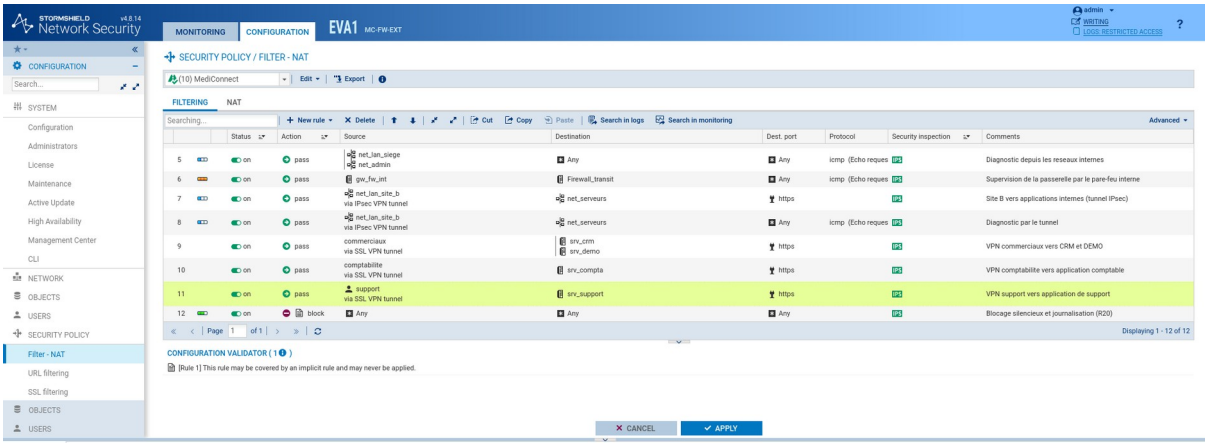


Figure 25 : *Suite de la même politique : règles réservées au tunnel IPsec, puis une règle par groupe d'utilisateurs arrivant par le VPN SSL, et le blocage final journalisé.*

7.3 Pare-feu interne

Interface	Flux autorisés
TRANSIT	Relais vers application (TCP 8443) ; site B vers zone SERVEURS (HTTPS, ICMP) ; nomades vers zone SERVEURS (HTTPS) ; nomades administrateurs vers le bastion (SSH) ; journaux du pare-feu externe vers le collecteur (UDP 514)
LAN	Poste d'administration vers le bastion (SSH) ; zone ADMIN et interfaces d'administration des deux pare-feux interdites et journalisées
ADMIN	Bastion vers l'administration des deux pare-feux (HTTPS) et vers le SSH de la zone SERVEURS

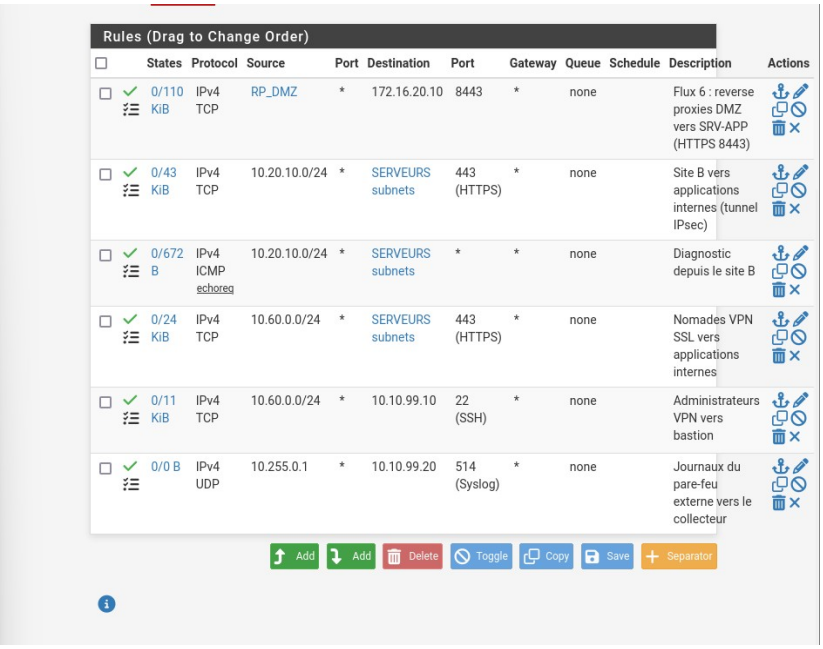


Figure 26 : *Interface TRANSIT du pare-feu interne, état final : chaque flux entrant depuis le pare-feu externe est autorisé de façon explicite et journalisé.*

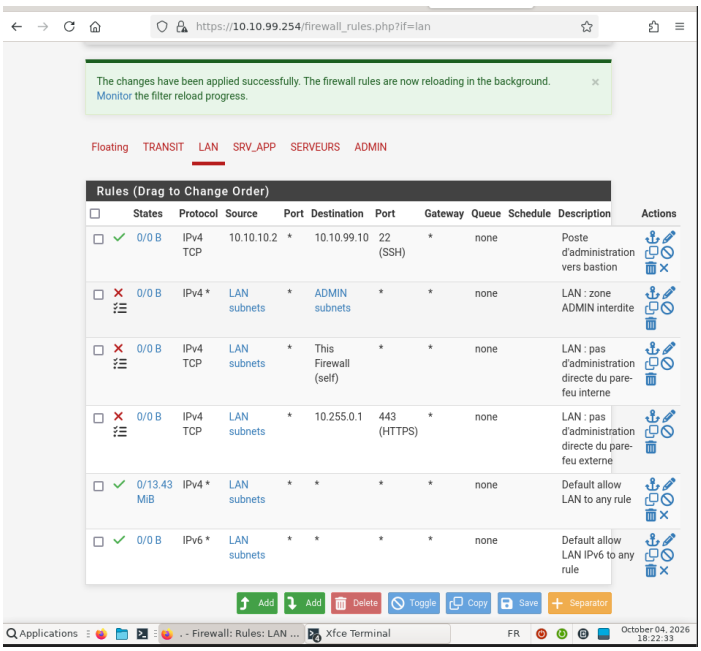


Figure 27 : *Interface LAN du pare-feu interne : seul le poste d'administration peut joindre le bastion ; la zone ADMIN et l'administration des pare-feux sont interdites au reste du LAN.*

7.4 Une politique corrigée grâce aux journaux

Juste après l'activation de la politique restrictive, le journal a montré un blocage toutes les demi-secondes : le pare-feu interne vérifie la disponibilité de sa passerelle par des pings, flux légitime absent de la matrice. Une règle dédiée, limitée à cette seule source, a été ajoutée. Une politique restrictive associée à la journalisation fait apparaître les flux réels.

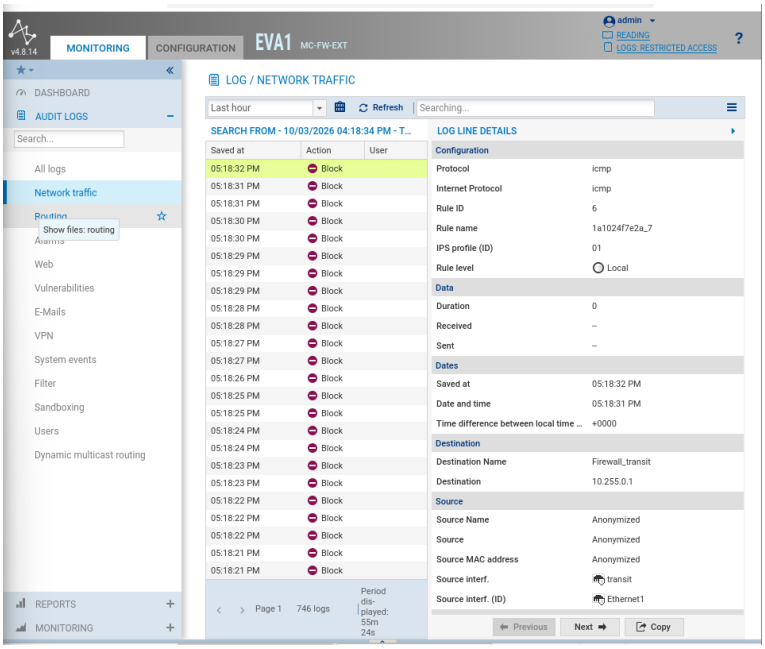


Figure 28 : *Journal du pare-feu externe : pings de supervision du pare-feu interne bloqués par la règle finale. Ce flux oublié dans la matrice a été identifié grâce aux journaux puis autorisé par une règle ciblée.*

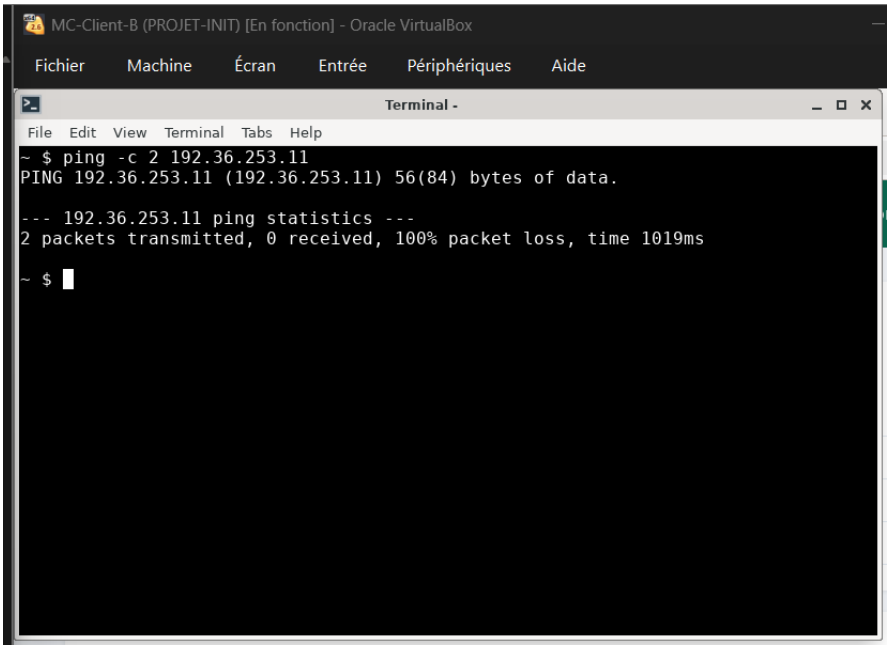


Figure 29 : *Depuis Internet, les adresses publiques ne répondent plus au ping : les paquets non autorisés sont jetés sans réponse (R20).*

8. Contrôle applicatif

8.1 Inspection par l'IPS

Le moteur de prévention d'intrusion du pare-feu externe analyse les flux autorisés : anomalies de protocole, techniques de contournement, attaques connues. Il est actif sur toutes les règles avec le profil par défaut.

Réglage ciblé. La navigation HTTPS par le relais sortant utilise la méthode CONNECT, que l'IPS bloquait (« Tunnelling using CONNECT method »). Plutôt que d'affaiblir la protection globale, un **profil d'inspection dédié** (IPS_05) autorise cette seule alarme en conservant sa journalisation, et il n'est appliqué qu'à la règle du LAN vers le relais sortant. Les flux venant d'Internet gardent le profil par défaut.

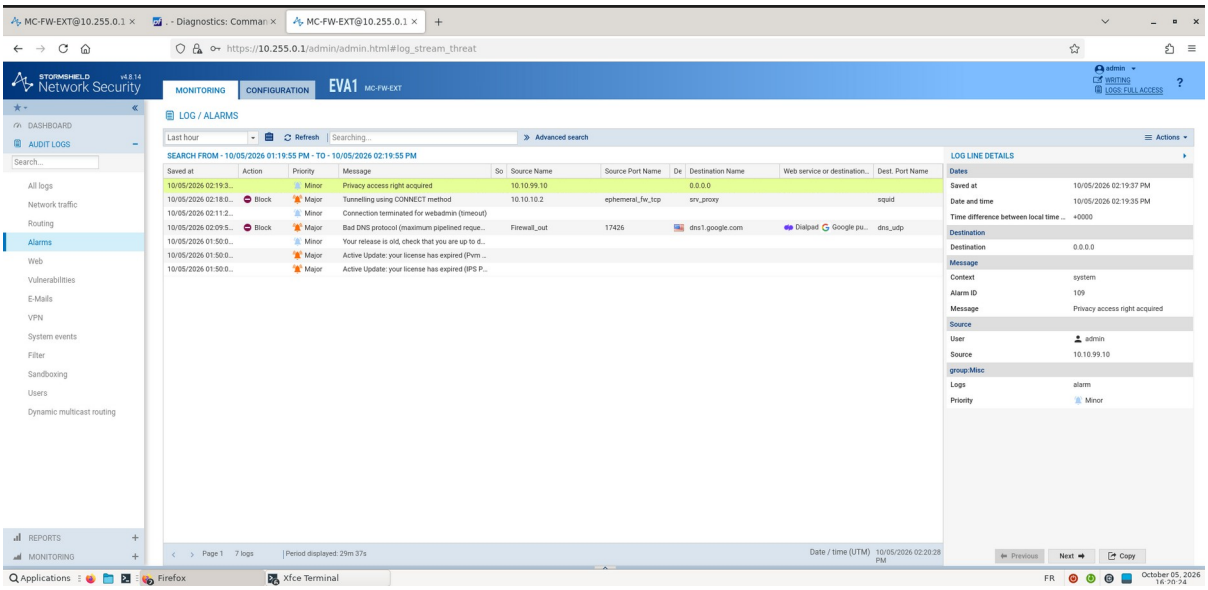


Figure 30 : *Journal des alarmes : l'IPS bloque le tunnel CONNECT entre un poste du LAN et le relais sortant. On y voit aussi l'alerte d'expiration de la licence de mise à jour des signatures (voir les limites).*

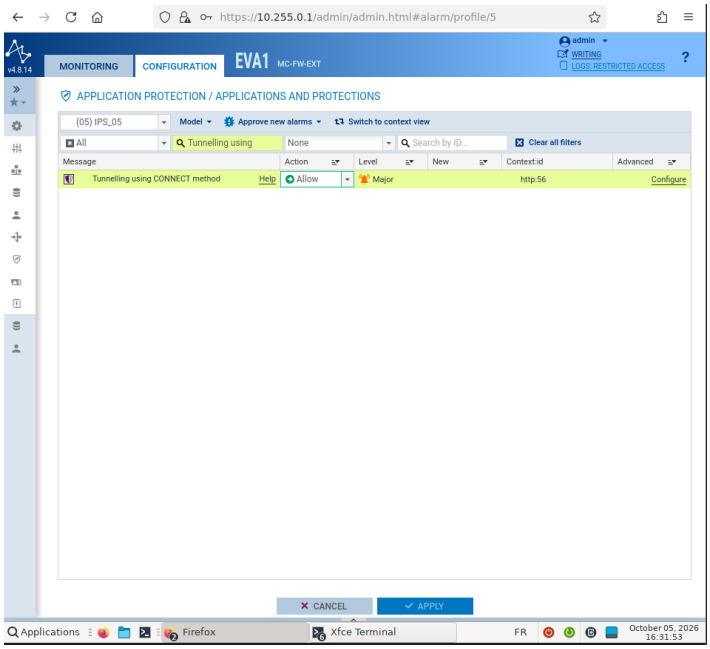


Figure 31 : *Profil d'inspection IPS_05 : la seule alarme « Tunnelling using CONNECT method » passe en Allow, avec un niveau Major conservé pour qu'elle reste tracée.*

8.2 Relais sortant

Les postes du LAN n'ont **aucune route vers Internet** (R19). Pour naviguer, ils passent par un relais Squid placé en DMZ : seul le LAN du siège est accepté, ports 80 et 443, CONNECT limité au port 443, liste de domaines refusés, aucun cache, adresse interne et version masquées, journal de chaque requête. Le pare-feu externe masque l'adresse du relais derrière son adresse publique (**R21**) et n'autorise le relais à résoudre des noms qu'auprès de deux résolveurs DNS désignés.

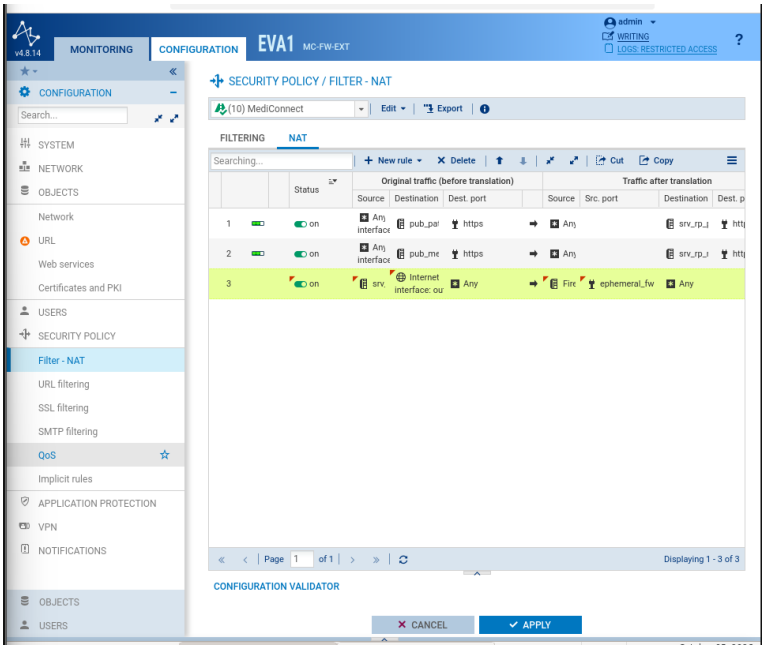


Figure 32 : *Règles de NAT du pare-feu externe : en plus des deux publications, la source du relais sortant est remplacée par l'adresse publique du pare-feu (masquage, R21).*

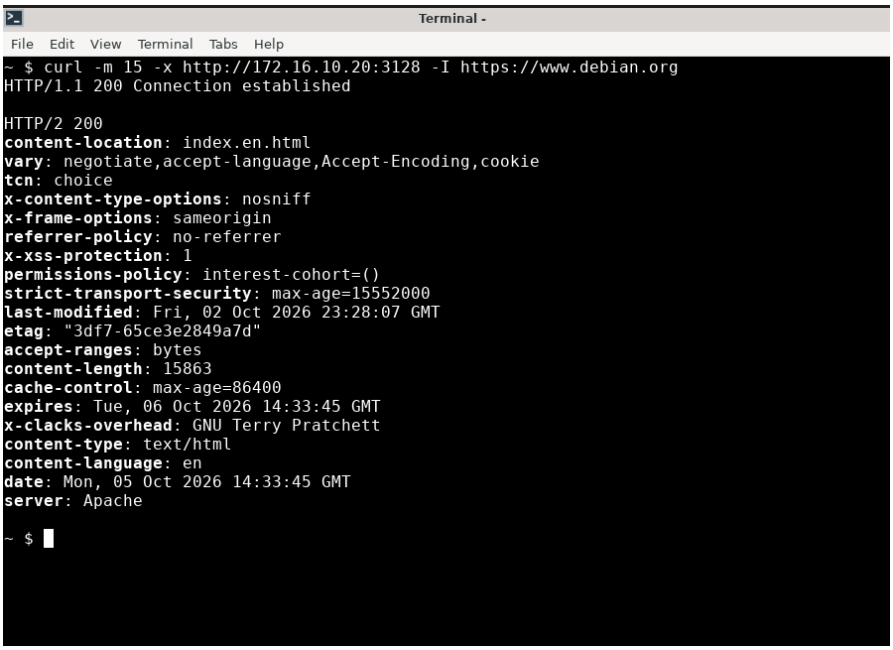


Figure 33 : *Après le réglage de l'IPS, un poste du LAN atteint un site HTTPS à travers le relais (tunnel établi puis réponse HTTP/2 200). La sortie directe, elle, reste impossible.*

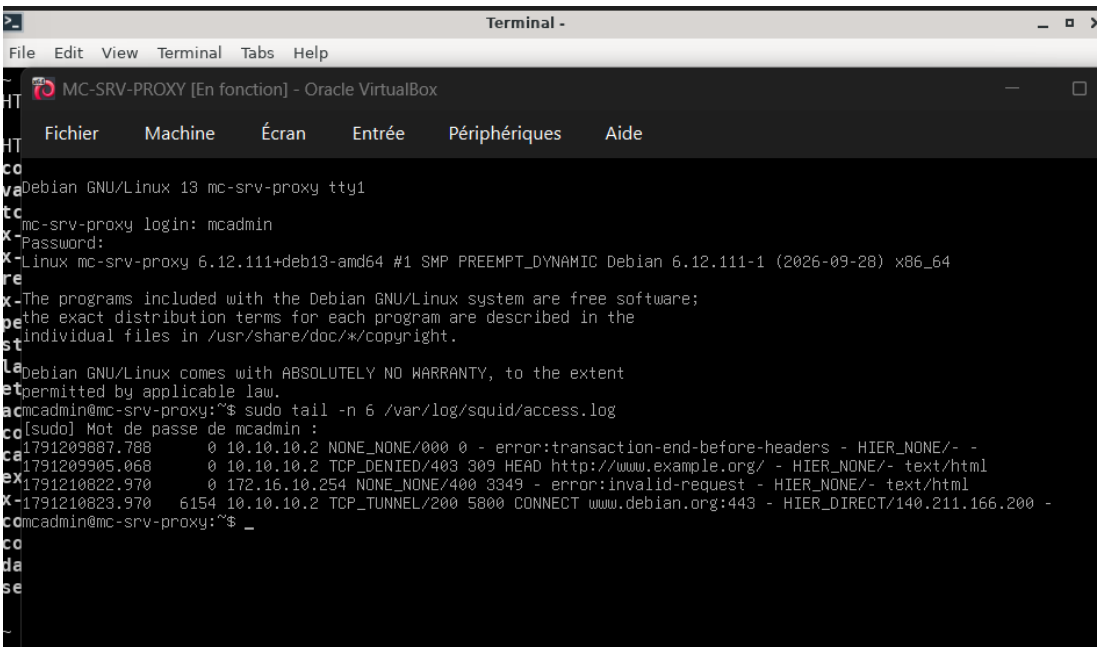


Figure 34 : *Journal du relais sortant : tunnel coupé par l'IPS avant réglage, domaine interdit refusé (403), puis tunnel HTTPS établi, chaque ligne portant l'adresse du poste.*

9. Sécurisation de l'administration

Le sujet exige qu'**un utilisateur du LAN ne puisse pas administrer directement les équipements** ; c'est aussi la recommandation R16. L'administration passe donc exclusivement par un **bastion** placé dans la zone ADMIN (10.10.99.10), la plus protégée.

- Le poste d'administration ouvre une session SSH sur le bastion avec redirection dynamique ; son navigateur utilise ce tunnel pour joindre les interfaces web d'administration, qui voient donc le bastion comme seule origine.
- Pare-feu externe : seul le bastion figure dans les hôtes autorisés à l'administration, délai d'inactivité des sessions réduit, protection contre la force brute active.
- Pare-feu interne : règle de secours « anti-lockout » désactivée ; depuis le LAN, la zone ADMIN et les interfaces d'administration sont interdites et journalisées.
- Les administrateurs d'astreinte en VPN SSL n'ont qu'une seule destination : le bastion, en SSH.
- Tous les mots de passe d'usine des pare-feux ont été remplacés.

La bascule a suivi un ordre précis pour ne pas perdre l'accès : instantanés des machines, ouverture et test du chemin par le bastion, bascule de la session d'administration sur ce chemin, puis fermeture de l'accès direct.

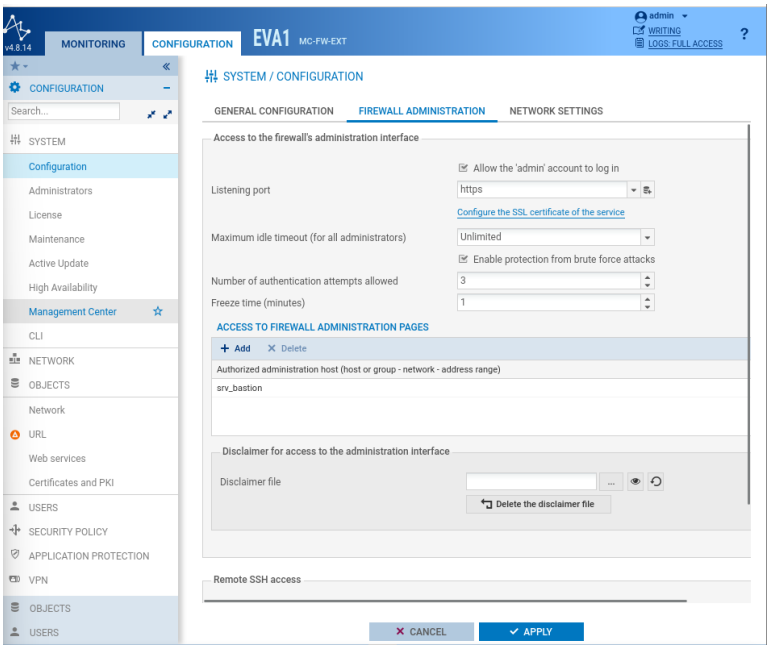


Figure 35 : *Pare-feu externe : seul l'objet srv_bastion est autorisé à accéder aux pages d'administration, et la protection contre la force brute est activée.*

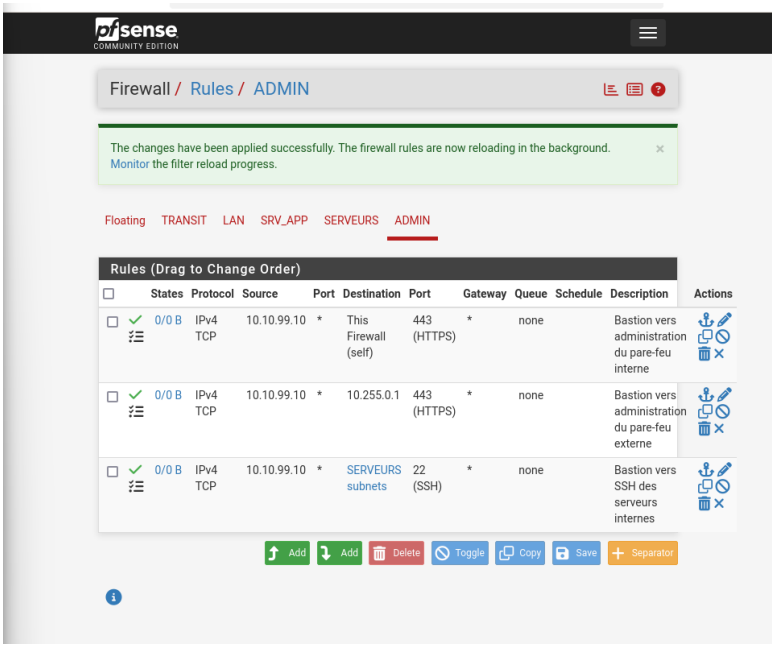


Figure 36 : *Interface ADMIN du pare-feu interne : le bastion est seul autorisé vers l'administration des deux pare-feux et vers le SSH de la zone SERVEURS.*

```
File  Edit  View  Terminal  Tabs  Help
~ $ which ssh
/usr/bin/ssh
~ $ ssh mcadmin@10.10.99.10
The authenticity of host '10.10.99.10 (10.10.99.10)' can't be established.
ED25519 key fingerprint is SHA256:85YVQ2XGh1DbcfyLIbUhXrosaYxFWoE6WDM6TyRhz9M.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.99.10' (ED25519) to the list of known hosts.
mcadmin@10.10.99.10's password:
Linux mc-srv-admin 6.12.111+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.111-1 (2026-09-28) x
86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Oct  4 17:44:15 2026 from 10.0.2.2
mcadmin@mc-srv-admin:~$ curl -k -m 5 -o /dev/null -s -w "%{http_code}\n" https://10.255.0.1/adm
in/
curl -k -m 5 -o /dev/null -s -w "%{http_code}\n" https://10.10.99.254/
exit
200
200
déconnexion
Connection to 10.10.99.10 closed.
~ $
```

Figure 37 : *Rebond SSH sur le bastion puis accès aux interfaces d'administration des deux pare-feux depuis le bastion (réponses HTTP 200).*

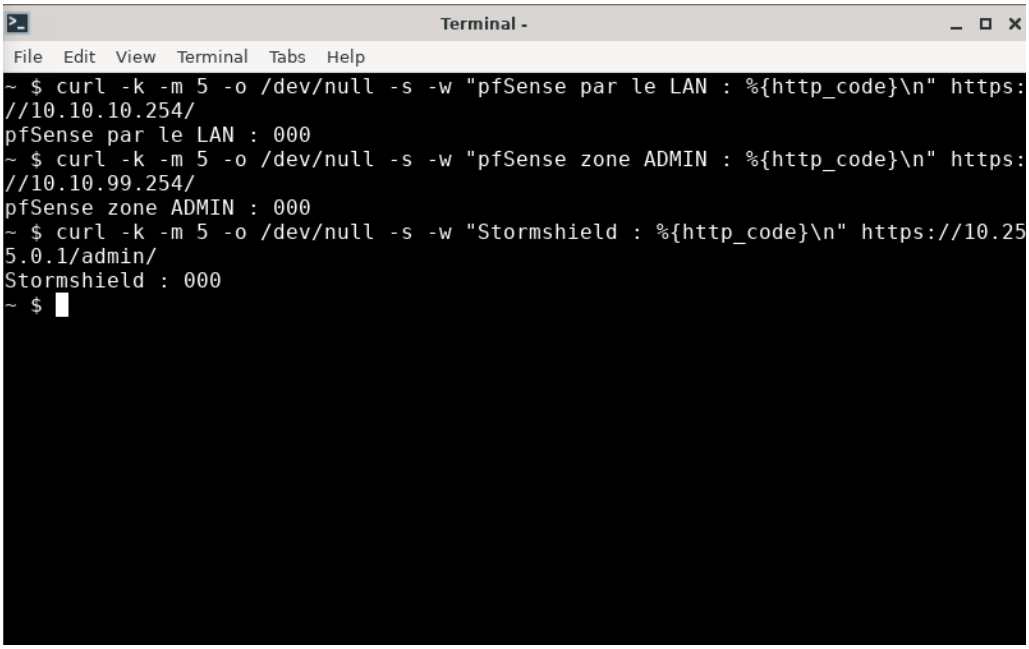


Figure 38 : *Depuis un poste du LAN, sans passer par le bastion : aucune interface d'administration ne répond (code 000). L'exigence du sujet est respectée.*

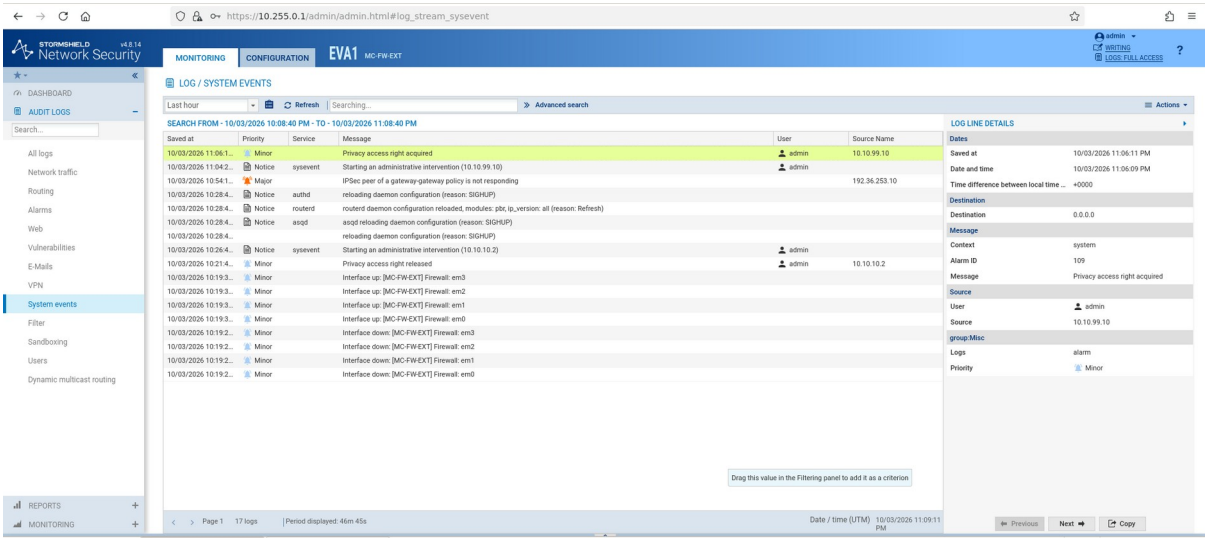


Figure 39 : *Journal système du pare-feu externe : la session d'administration est ouverte depuis 10.10.99.10 (le bastion), alors que la précédente venait d'un poste du LAN.*

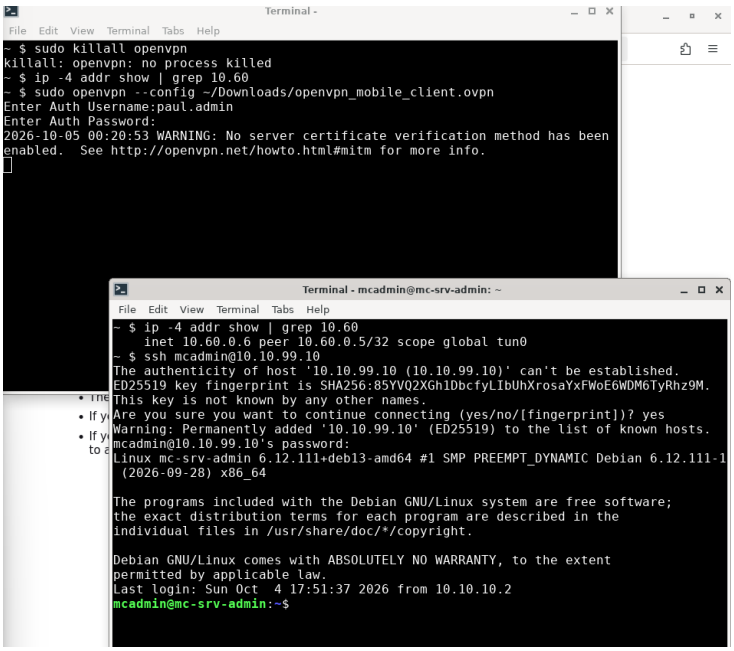


Figure 40 : *Administrateur d'astreinte connecté en VPN SSL : sa seule destination permise est le bastion, en SSH.*

10. Stratégie de journalisation

Un équipement compromis ne doit pas pouvoir effacer ses propres traces. Une copie des journaux est donc envoyée vers un **collecteur centralisé** situé dans la zone ADMIN (**R26**) : rsyslog écoute sur 10.10.99.20 en UDP 514 et range les événements dans un fichier par équipement émetteur.

- **Pare-feu externe** : profil syslog vers le collecteur, format RFC 5424 (filtrage, connexions, alarmes IPS, événements système et VPN).
- **Pare-feu interne** : journalisation distante de l'ensemble de ses journaux, émise depuis son interface ADMIN.
- **Services de la DMZ** : journal du portail MFA et journal du relais sortant, conservés localement (voir les limites).
- **Horodatage** : le pare-feu externe est synchronisé par NTP ; les autres équipements ont été remis à l'heure. Sans heure juste, les journaux ne peuvent pas servir de preuve, et les codes TOTP sont refusés.

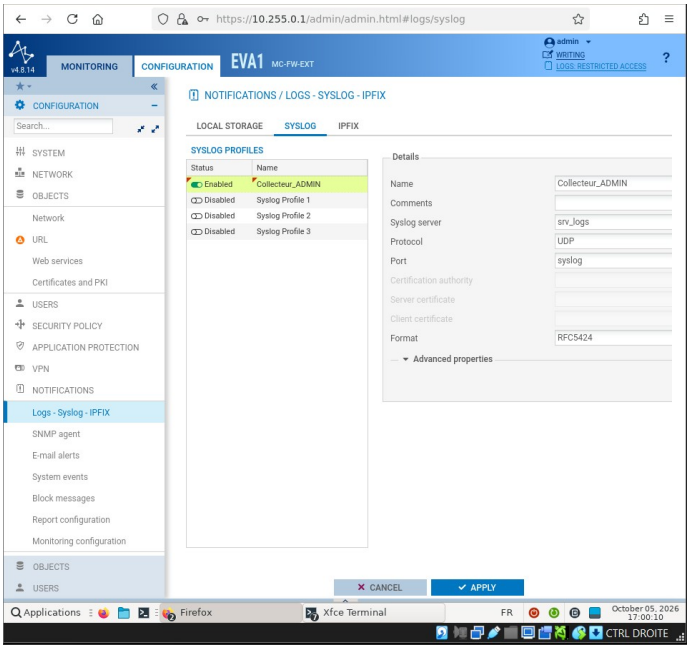


Figure 41 : *Pare-feu externe : profil syslog Collecteur_ADMIN vers le collecteur, en UDP, au format RFC 5424.*

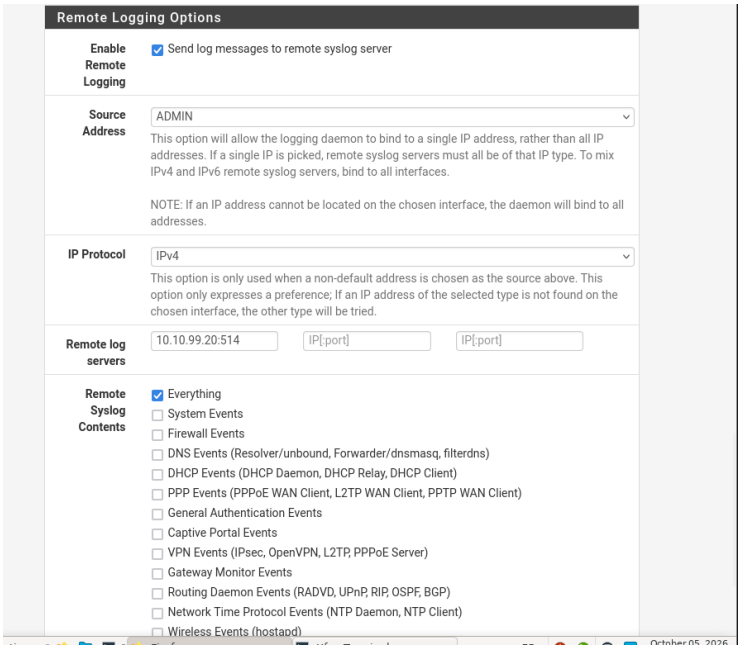


Figure 42 : *Pare-feu interne : envoi de tous ses journaux vers le collecteur 10.10.99.20, depuis son interface ADMIN.*

```
mcadmin@mc-srv-admin:~$ ls -l /var/log/mediconnect/central/
total 8
-rw-r--r-- 1 root root 1887  5 oct.  17:00 10.10.99.254.log
-rw-r--r-- 1 root root 1260  5 oct.  17:00 10.255.0.1.log
mcadmin@mc-srv-admin:~$ sudo tail -n 3 /var/log/mediconnect/central/10.255.0.1.log
2026-10-05T15:00:34+00:00 MC-FW-EXT asqd id=firewall time="2026-10-05 15:00:34" fw="MC-FW-EXT" tz=+0000 startime="2026-10-05 15:00:34" pri=5 service=asqd msg="asqd reloading daemon configurat
ion (reason: SIGHUP)" logtype="system"
2026-10-05T15:00:34+00:00 MC-FW-EXT routerd id=firewall time="2026-10-05 15:00:34" fw="MC-FW-EXT" tz=+0000 startime="2026-10-05 15:00:34" pri=5 service=routerd msg="routerd daemon configurati
on reloaded, modules: pbr, ip_version: all (reason: Refresh)" logtype="system"
2026-10-05T15:00:34+00:00 MC-FW-EXT serverd id=firewall time="2026-10-05 15:00:34" fw="MC-FW-EXT" tz=+0000 startime="2026-10-05 15:00:34" error=0 user="admin" address=10.10.99.10 sessionid=16
 msg="CONFIG COMMUNICATION ACTIVATE" logtype="server"
mcadmin@mc-srv-admin:~$
```

Figure 43 : *Sur le collecteur, un fichier par équipement. On y lit une activation de configuration du pare-feu externe par l'administrateur depuis le bastion : administration séparée et journalisation se confirment mutuellement.*

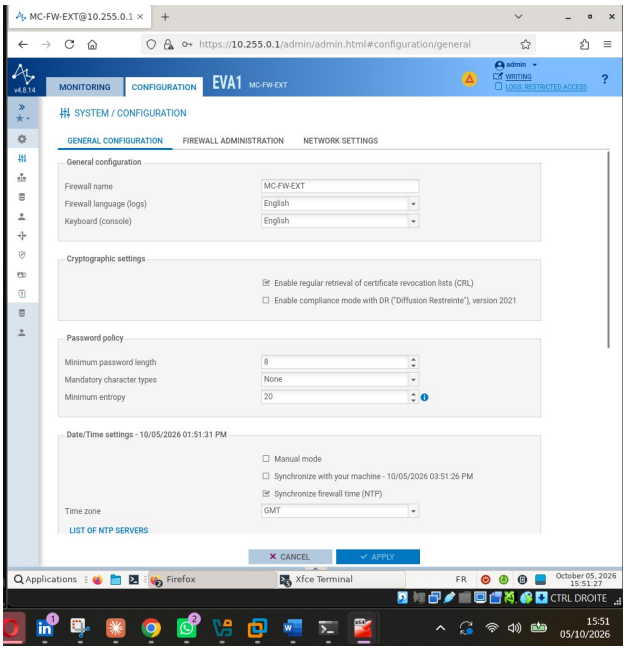


Figure 44 : *Pare-feu externe synchronisé par NTP. Avant la synchronisation, son horloge avait plus d'un jour de décalage, ce qui rendait les journaux inexploitables.*

11. Tests réalisés

11.1 Tests fonctionnels

Chaque brique a été validée par des tests positifs (le flux prévu passe) et négatifs (le flux non prévu est refusé), consignés dans le journal de bord :

Domaine	Test	Résultat
Routage	Poste du LAN vers pare-feu interne, pare-feu externe, DMZ et DEMO	OK, un saut par le pare-feu interne
Publication	Portail patients et espace médecins depuis Internet	OK
Séparation des chaînes	Espace professionnel par l'adresse des patients	Refusé (403)
Filtrage	Ping des adresses publiques depuis Internet	Aucune réponse, tentative journalisée
DEMO	Serveur de démonstration vers DMZ, application et LAN	Tout échoue
IPsec	Site B vers les trois applications de la zone SERVEURS	OK, chiffré
IPsec	Site B vers le LAN du siège et la DMZ	Refusé
VPN SSL	Commerciale : CRM et DEMO / comptabilité et support	Autorisés / refusés
VPN SSL	Comptable : comptabilité / CRM et DEMO	Autorisée / refusés
MFA	Code faux, puis code valide	Refusé, puis accès
Administration	Depuis le bastion / depuis le LAN directement	Accès / aucune réponse
Relais sortant	Sortie directe, domaine interdit, site HTTPS par le relais	Impossible, 403, OK
Journalisation	Fichiers par équipement sur le collecteur	Reçus, horodatés

11.2 Tests depuis un poste attaquant

Pour valider la sécurité du point de vue d'un attaquant, une machine Kali Linux a été placée sur l'Internet simulé (adresse 192.36.253.66), face aux adresses publiques du pare-feu externe. Les tests sont restés limités à la maquette du projet. Cinq scénarios ont été joués, puis les traces ont été recherchées côté défense.

Scénario	Résultat observé	Ce que cela démontre
Découverte des ports des deux portails publiés	Seul le port 443 répond ; les autres ports restent sans réponse	Surface d'exposition minimale, rejet silencieux (R20)
Découverte sur l'adresse du pare-feu et l'ancienne adresse DEMO	DEMO injoignable ; seul le portail VPN répond sur le pare-feu	DEMO non publiée, administration non exposée
Identification des services exposés	Serveur web sans numéro de version, portail d'authentification	Seuls les relais sont visibles, pas l'application
Accès aux pages sensibles	Espace pro : redirection vers la MFA ; espace pro côté patients : 403 ; administration : 403	MFA obligatoire, cloisonnement des chaînes, R16
Tentatives répétées de connexion au portail MFA	5 refus (401) puis blocage (429)	Protection contre la force brute

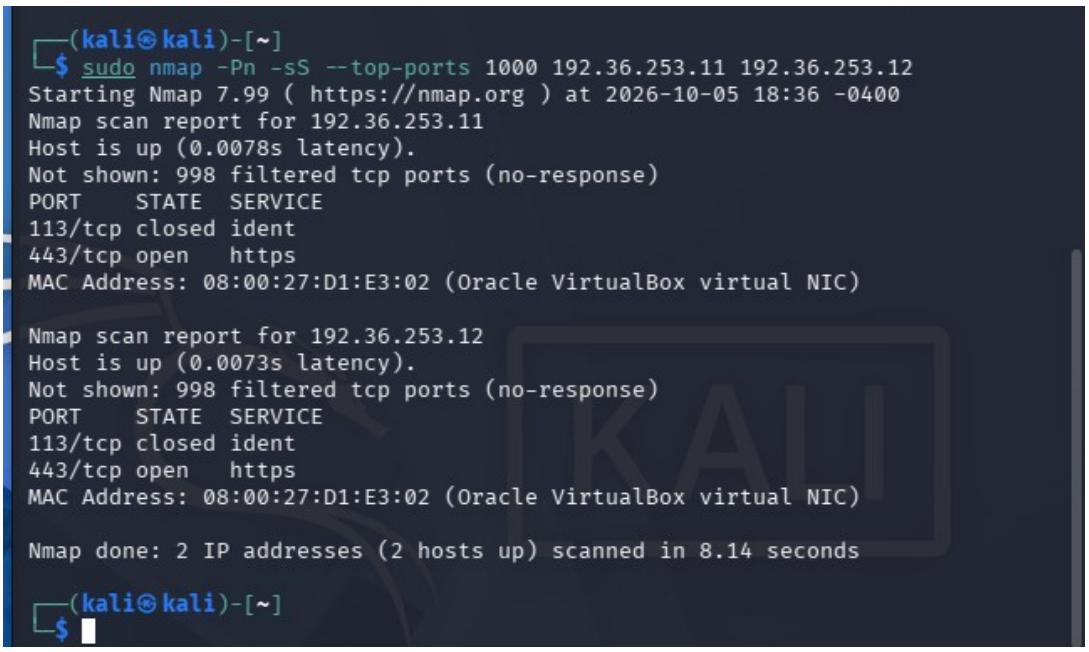


Figure 45 : *Découverte des ports depuis le poste attaquant : sur les deux adresses publiées, seul le port 443 est ouvert et 998 ports restent filtrés. Les deux adresses ont la même adresse MAC, celle du pare-feu : le serveur d'application est invisible.*

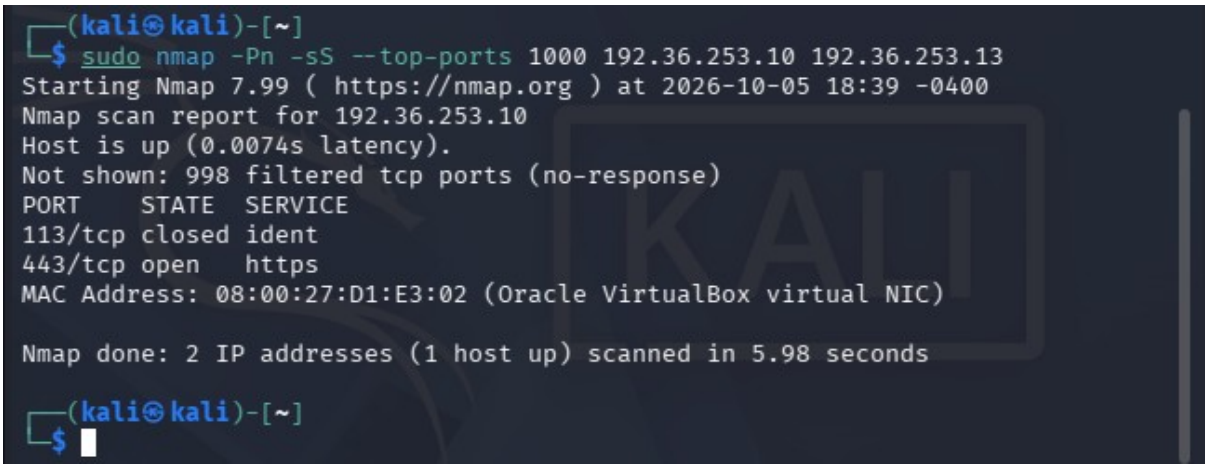


Figure 46 : *Sur l'adresse propre du pare-feu, seul le portail VPN SSL répond en 443 ; l'ancienne adresse de démonstration ne répond plus du tout.*

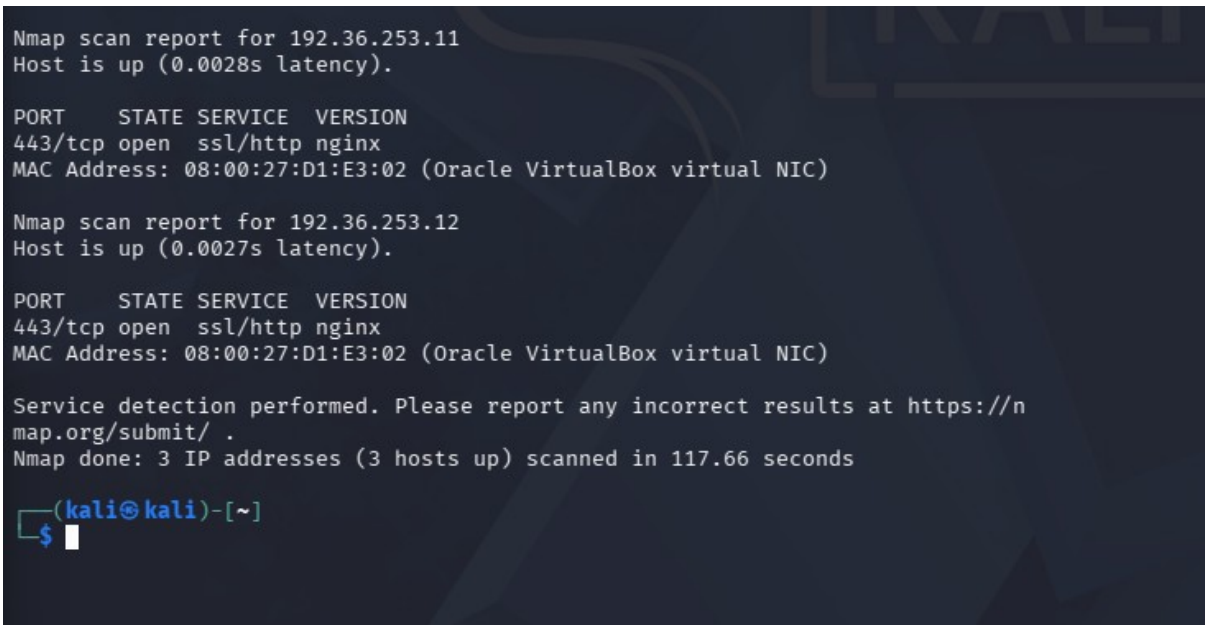


Figure 47 : *Identification des services : les deux portails sont servis par nginx, sans numéro de version divulgué.*



Figure 48 : *Contrôle d'accès vu de l'attaquant : l'espace professionnel redirige vers la page MFA, il est refusé (403) par la chaîne patients, et l'administration du pare-feu est refusée (403).*



Figure 49 : *Tentatives répétées de connexion sur le portail des médecins : les cinq premières sont refusées (401), les suivantes sont bloquées (429) pendant cinq minutes.*

11.3 Traces côté défense

Sur le collecteur, le fichier du pare-feu externe contient **6 067 événements** liés à l'adresse de l'attaquant : **5 986 paquets bloqués** et seulement **81 connexions autorisées**, toutes sur le port 443 des services publiés. Une partie des blocages correspond à des **alarmes de l'IPS** (par exemple une anomalie de protocole TLS levée pendant l'identification des services). Côté serveur, le journal du portail MFA trace les cinq échecs puis le blocage, avec l'adresse de l'attaquant.

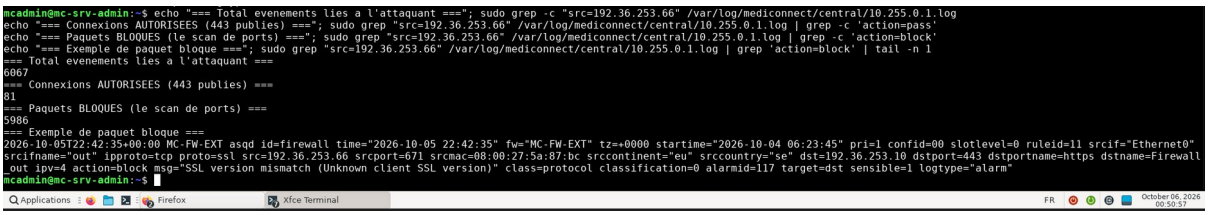


Figure 50 : *Journal centralisé : 6 067 événements de l'attaquant, dont 5 986 bloqués et 81 autorisés. L'exemple affiché est une alarme IPS (« SSL version mismatch ») avec action de blocage.*

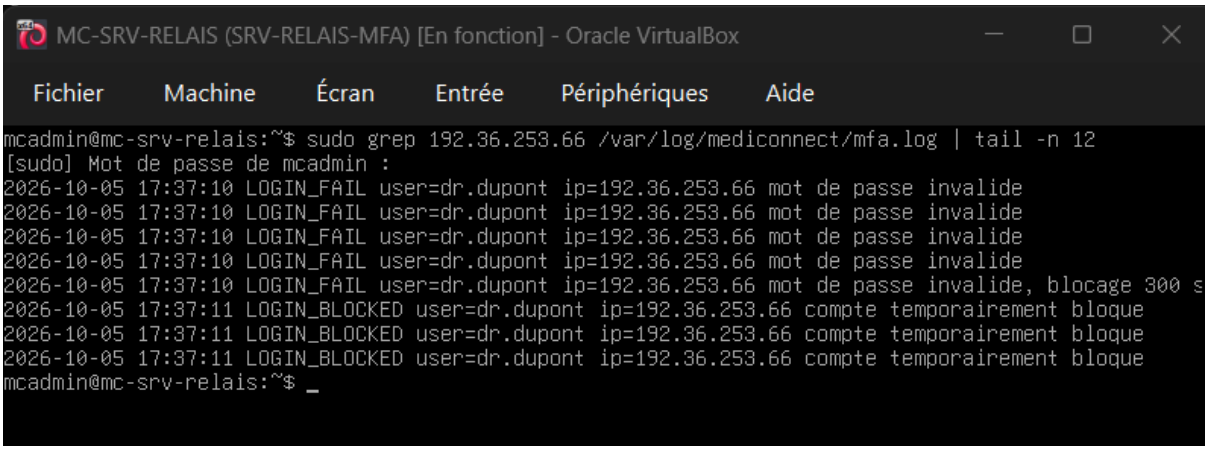


Figure 51 : *Journal du portail MFA sur le relais : cinq échecs pour le compte dr.dupont depuis l'adresse de l'attaquant, puis blocage de 300 secondes. Ce même compte s'était connecté normalement depuis un poste légitime : l'utilisateur légitime passe, l'attaquant est bloqué.*

12. Limites de la solution

La maquette applique les principes du guide, mais plusieurs choix sont propres à un environnement de laboratoire. Ils sont identifiés ci-dessous avec la mesure attendue en production.

Domaine	Limite constatée	En production
Architecture	Commutation virtuelle partagée par VirtualBox (R12) ; le pare-feu interne joue aussi le rôle de pare-feu intermédiaire (R5)	Équipements et commutateurs dédiés, pare-feu intermédiaire distinct
Architecture	Plusieurs relais sur une même machine (R11) ; relais sortant dans la même DMZ que les relais entrants	Un serveur par relais, DMZ dédiée aux flux sortants
Disponibilité	Aucune redondance d'accès Internet ni protection anti-DDoS (R17, R18)	Double raccordement, offre anti-DDoS
VPN	Tunnel IPsec authentifié par clé partagée	Authentification par certificats
Identité	Droit VPN accordé utilisateur par utilisateur (droit de groupe non appliqué par cette version)	Droits par groupe, annuaire dédié durci
MFA	Service développé pour la maquette, compteurs d'échecs en mémoire	Fournisseur d'identité éprouvé, clés FIDO2
Administration	Bastion authentifié par mot de passe ; serveurs de la DMZ non administrés par le bastion	Clés SSH et second facteur, enregistrement des sessions
Contrôle applicatif	Licence de mise à jour des signatures IPS expirée	Abonnement actif, signatures à jour
Filtrage	Le port 113 répond par un refus explicite au lieu d'être ignoré	Rejet silencieux sur tous les ports non publiés
Journalisation	Syslog en UDP non chiffré ; collecteur et bastion sur la même machine ; journaux de la DMZ non centralisés (R7)	Syslog sur TLS, collecteur dédié, collecteur intermédiaire en DMZ
Temps	Pas de serveur NTP interne, horloges remises à la main après les pauses	Serveur NTP interne pour tout le SI
Conformité	Le guide PA-066 est nécessaire mais pas suffisant pour des données de santé	RGPD, hébergement certifié HDS

13. Conclusion

La maquette MediConnect met en œuvre une interconnexion à Internet conforme aux principes du guide PA-066 : deux pare-feux de technologies différentes, une DMZ dont rien ne sort vers l'intérieur hors du flux applicatif prévu, des chaînes séparées pour les patients et les médecins, une authentification à deux facteurs pour l'espace professionnel, des VPN chiffrés avec des droits fondés sur l'identité, une administration réservée à un bastion et une journalisation centralisée.

La campagne de tests finale montre que ces mesures tiennent face à un attaquant externe : seul le port nécessaire est visible, les pages sensibles sont protégées, les tentatives répétées sont bloquées, et chaque action est tracée côté défense. Le projet a aussi montré l'intérêt d'une démarche itérative : plusieurs erreurs (déclaration d'objets, flux oublié, publication non conforme au cadrage) ont été détectées grâce aux tests et aux journaux, puis corrigées.

Les limites relevées en section 12 indiquent les évolutions nécessaires pour un passage en production, en particulier sur la robustesse de l'authentification, la disponibilité et la conformité propre aux données de santé.

Annexe A. Correspondance avec les recommandations ANSSI

Réf.	Recommandation (résumé)	Mise en œuvre dans MediConnect
R1	Identifier les besoins d'interconnexion	Tableau des besoins, matrice des flux
R2, R3, R13	Passerelle à plusieurs niveaux, pare-feux externe et interne distincts	Stormshield en externe, pfSense en interne
R5	Pare-feu entre relais et applications	Application isolée en zone SRV-APP derrière le pare-feu interne
R6	Chaînes séparées selon les populations	Deux adresses publiques, deux relais, deux politiques (patients, médecins)
R7	Pas de flux initié de la DMZ vers le SI interne	Seul flux : relais vers application en TCP 8443
R8	Rupture protocolaire	Relais nginx terminant le TLS
R10	Pas d'annuaire interne interrogé depuis la DMZ	Annuaire propre au pare-feu externe, base MFA locale à la DMZ
R16	Administration par un réseau dédié	Bastion en zone ADMIN, accès direct depuis le LAN interdit
R19	Routage statique, pas de route par défaut interne	Routes statiques, aucune passerelle par défaut sur le pare-feu interne
R20	Rejet silencieux des flux non autorisés	Blocage final journalisé, aucune réponse côté Internet
R21	Masquage des adresses internes	NAT de masquage du relais sortant
R26	Journalisation centralisée	Collecteur rsyslog en zone ADMIN

Annexe B. Inventaire de la maquette

Machine	Zone	Adresse(s)	Rôle
MC-FW-EXT	Bordure	192.36.253.10 à .12, 172.16.10.254, 172.16.30.254, 10.255.0.1	Pare-feu externe Stormshield
MC-FW-INT	Interne	10.255.0.2 et .254 de chaque zone interne	Pare-feu interne pfSense
MC-FW-B	Site B	192.36.253.20, 10.20.10.254	Pare-feu du site B
MC-SRV-RELAIS	DMZ-RELAIS	172.16.10.10 et .11	Relais patients, relais médecins, portail MFA
MC-SRV-PROXY	DMZ-RELAIS	172.16.10.20	Relais sortant Squid
MC-SRV-APP	SRV-APP	172.16.20.10	Application MediConnect
MC-SRV-DEMO	DEMO	172.16.30.10	Plateforme de démonstration
MC-SRV-INTERNE	SERVEURS	10.10.20.20, .30, .40	CRM, comptabilité, support
MC-SRV-ADMIN	ADMIN	10.10.99.10 et .20	Bastion et collecteur de journaux
MC-Client-LAN	LAN-SIEGE	10.10.10.2	Poste du siège et d'administration
MC-Client-B	LAN-SITE-B / Internet	10.20.10.2 ou 192.36.253.100	Poste du site B, poste nomade
Kali Linux	Internet	192.36.253.66	Poste attaquant des tests